

《信息系统安全》第十五讲

Oracle安全概述

2023年12月25日

周亚建

yajian@bupt.edu.cn

Overview of Last Class

你是否遇见过数据库系统安全问题？

你遇见的安全情况是什么症状？

你是怎么解决的？

这一讲要解决什么问题？

DB-Engines Ranking

Oracle数据库的安全性如何？

The DB-Engines Ranking ranks database management systems according to their popularity. The ranking is updated monthly.

Read more about the [method](#) of calculating the scores.



Oracle大量应用于金融、通信、生产制造、快速消费品零售、物流运输、医疗、互联网、政府

381 systems in ranking, December 2021

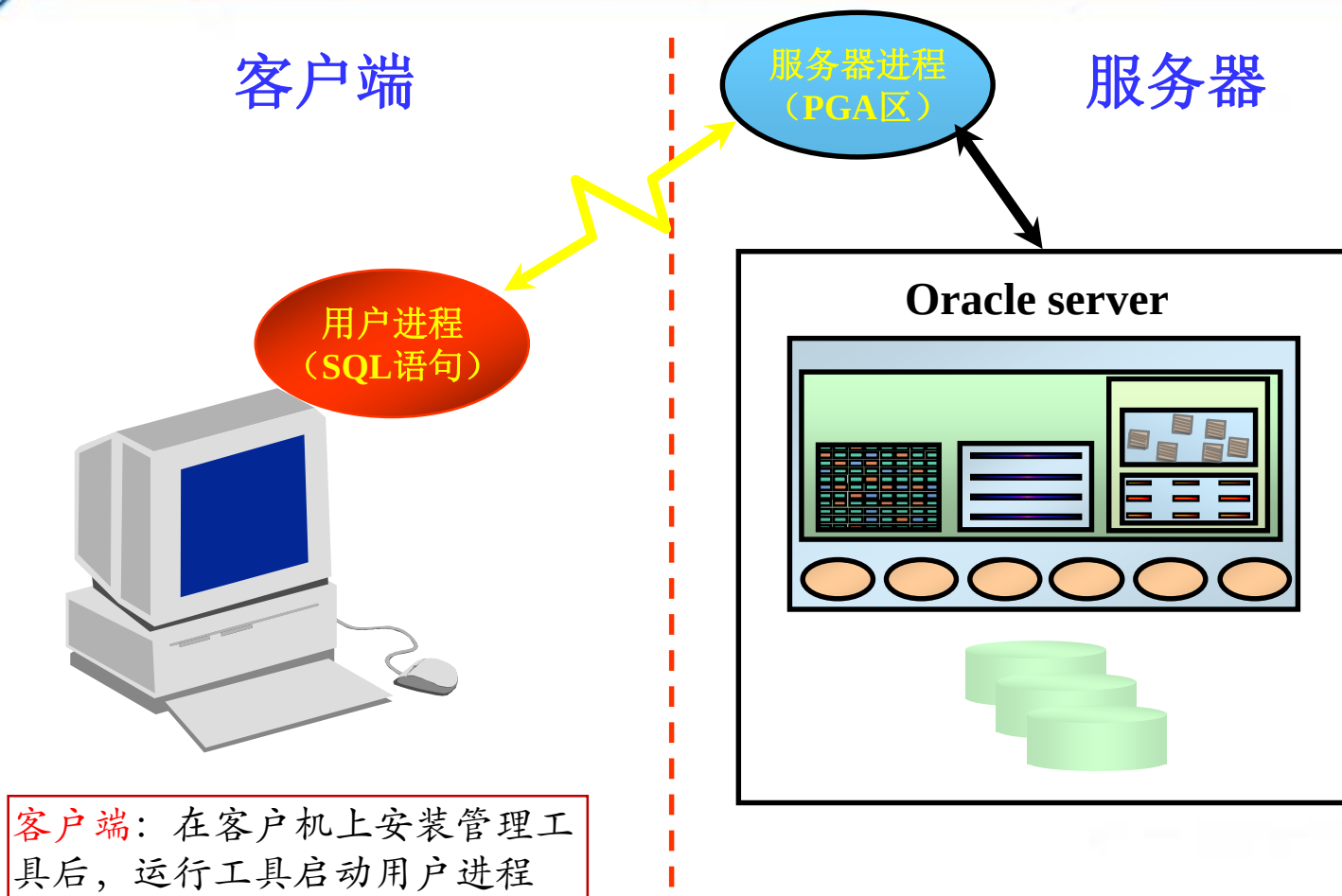
Rank			DBMS	Database Model	Score		
Dec 2021	Nov 2021	Dec 2020			Dec 2021	Nov 2021	Dec 2020
1.	1.	1.	Oracle +	Relational, Multi-model i	1281.74	+9.01	-43.86
2.	2.	2.	MySQL +	Relational, Multi-model i	1206.04	-5.48	-49.41
3.	3.	3.	Microsoft SQL Server +	Relational, Multi-model i	954.02	-0.27	-84.07
4.	4.	4.	PostgreSQL +	Relational, Multi-model i	608.21	+10.94	+60.64
5.	5.	5.	MongoDB +	Document, Multi-model i	484.67	-2.67	+26.95
6.	6.	↑ 7.	Redis +	Key-value, Multi-model i	173.54	+2.04	+19.91
7.	7.	↓ 6.	IBM Db2	Relational, Multi-model i	167.18	-0.34	+6.74
8.	8.	8.	Elasticsearch	Search engine, Multi-model i	157.72	-1.36	+5.23
9.	9.	9.	SQLite +	Relational	128.68	-1.12	+7.00
10.	↑ 11.	↑ 11.	Microsoft Access	Relational	125.99	+6.75	+9.25
11.	↓ 10.	↓ 10.	Cassandra +	Wide column	119.20	-1.68	+0.36
12.	12.	12.	MariaDB +	Relational, Multi-model i	104.36	+2.17	+10.75
13.	13.	13.	Splunk	Search engine	94.32	+2.02	+7.32
14.	↑ 15.	↑ 16.	Microsoft Azure SQL Database	Relational, Multi-model i	83.25	+1.93	+13.76



Oracle体系结构



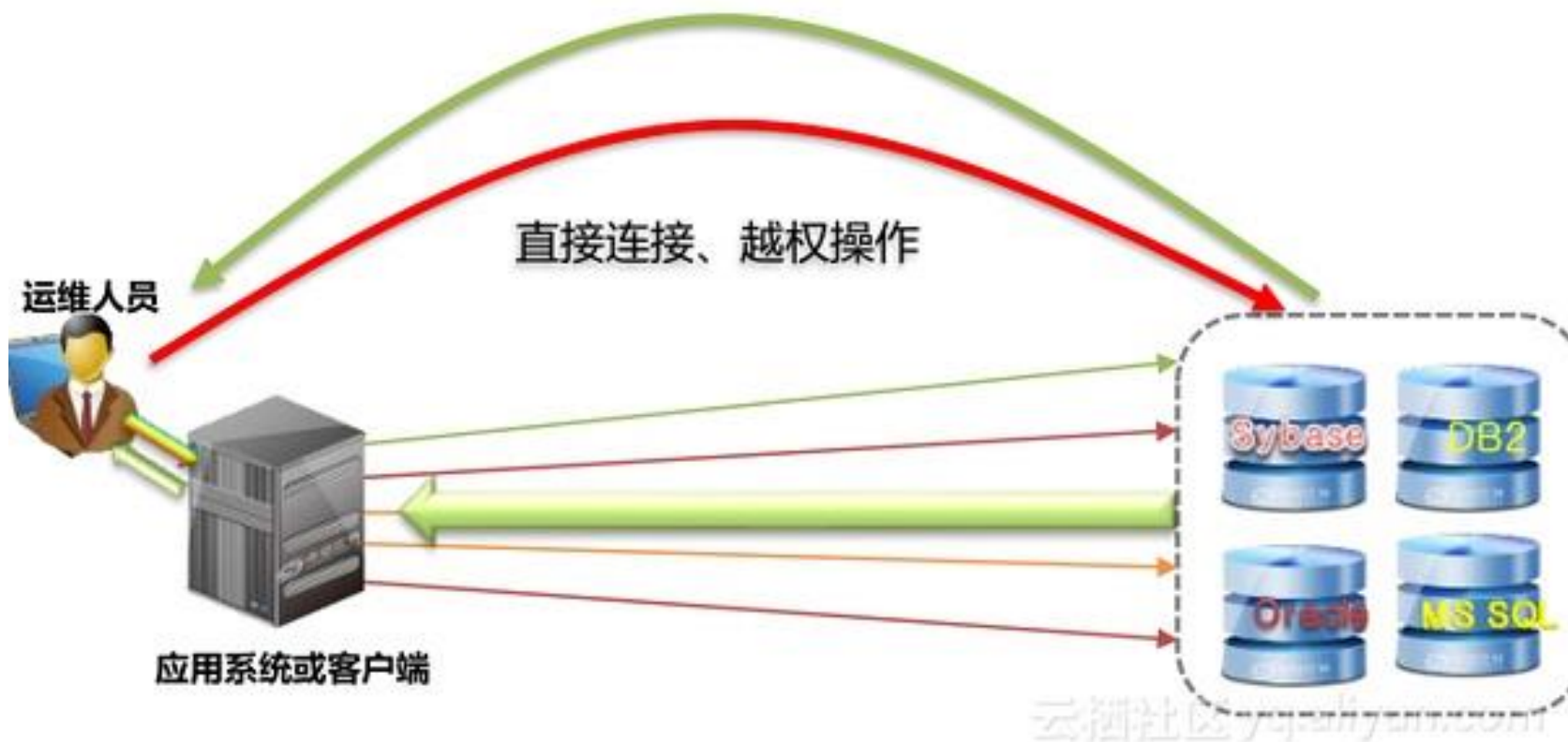
Oracle工作原理



Oracle的体系结构可分客户端、服务器两大部分



如果DBA删库跑路，会导致损失惨重

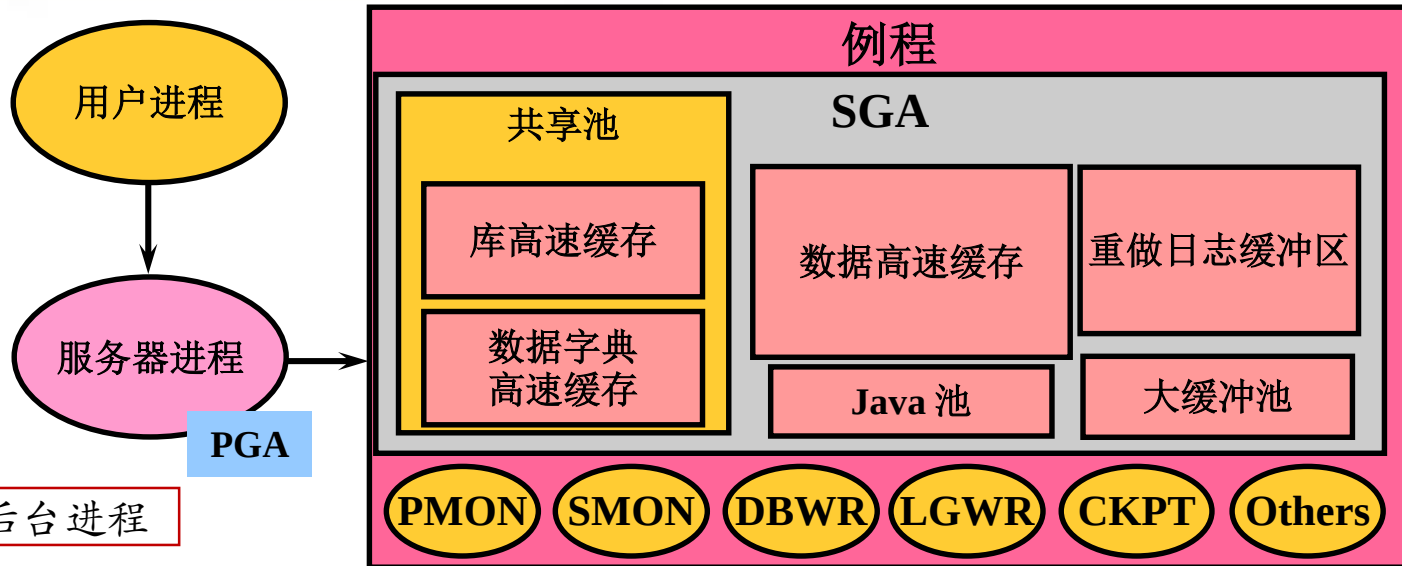




服务端的体系结构：例程+数据库

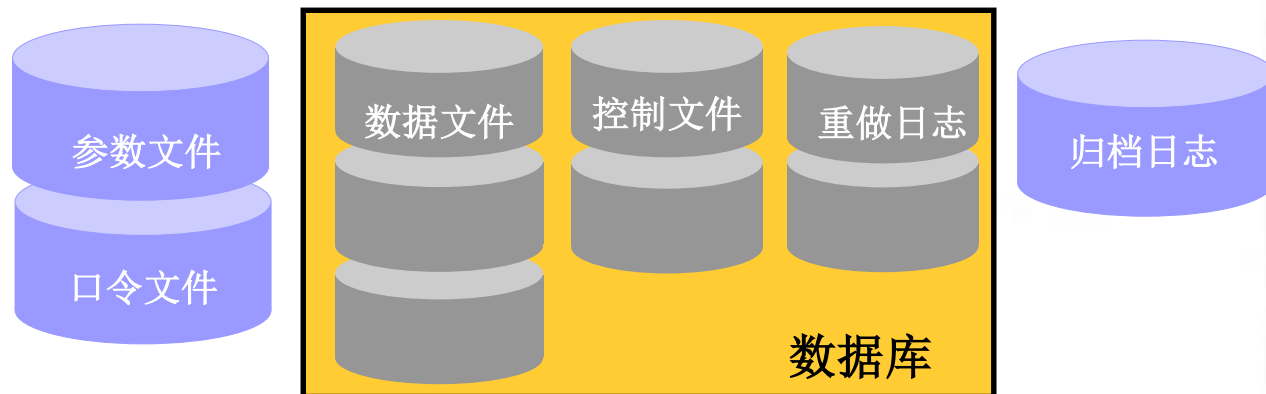
填空

涉及三种结构：
Oracle的内存结构
Oracle的进程结构
Oracle的存储结构



☀ 例程：SGA/PGA、后台进程

☀ 数据库：包括控制文件、数据文件、日志文件等操作系统文件。



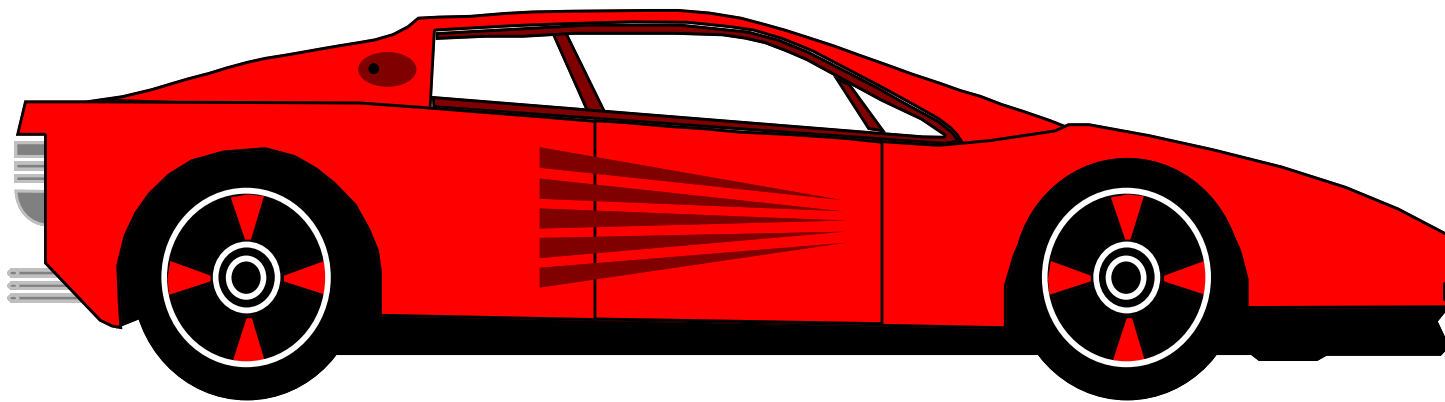
数据库：物理结构 & 逻辑结构



关于例程 (instance)

例程必考(形式未知)

如果把Oracle数据库比作一部汽车，instance相当于汽车的发动机，启动Oracle数据库前应先启动instance



当用户连接到数据库并使用数据库时，实际上是连接到该数据库的例程，通过例程来连接、使用数据库。

所以例程是用户和数据库之间的中间层。

例程与数据库的区别：

- 数据库指的是存储数据的物理结构，总是实际存在的；
- 例程则是由内存结构和一系列进程组成，可以启动和关闭。



Oracle 数据库的三种结构

内存结构

- SGA和PGA，使用内存最多的是SGA，同时也是影响数据库性能的最大参数

进程结构

- 包括前台进程、后台进程
- 前台进程是指服务进程和用户进程。前台进程是根据实际需要而运行的，并在需要结束后立刻结束
- 后台进程是指在Oracle数据库启动后，自动启动的几个操作系统进程

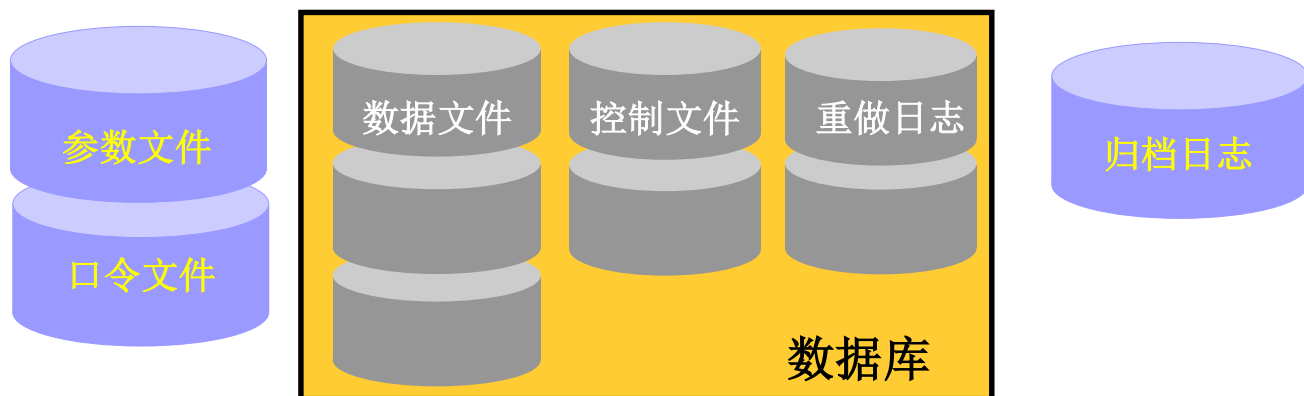
存储结构

- 分为逻辑存储结构、物理存储结构
- 逻辑存储结构是描述Oracle数据库中如何组织和管理数据，与操作系统平台无关
- 物理存储结构是数据库的外部存储结构。它对应操作系统相关文件，包括控制文件、数据文件、日志文件等操作系统文件



Oracle数据库的三种结构：存储结构

Oracle 保存数据的容器。分物理存储结构及逻辑存储结构。



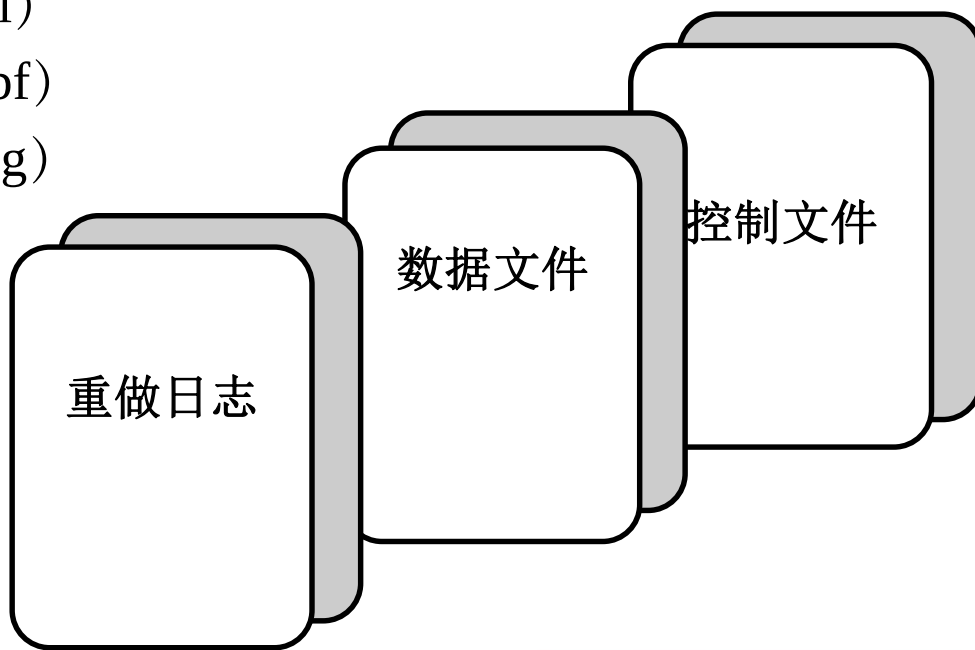


Oracle数据库物理存储结构

物理存储结构是现实的数据存储单元，对应于操作系统文件。Oracle数据库就是由驻留在服务器的磁盘上的这些操作系统文件所组成的，包括数据文件、日志文件、控制文件。

物理结构主要包括以下三种文件：

- 控制文件 (.ctl)
- 数据文件 (.dbf)
- 重做日志 (.log)





Oracle数据库物理存储结构：数据文件

数据文件（Data File）是物理存储Oracle数据库数据的文件。

其特点如下：

- 每一个数据文件只与一个数据库相联系
- 一个表空间可包含一个或多个数据文件
- 一个数据文件只能属于一个表空间

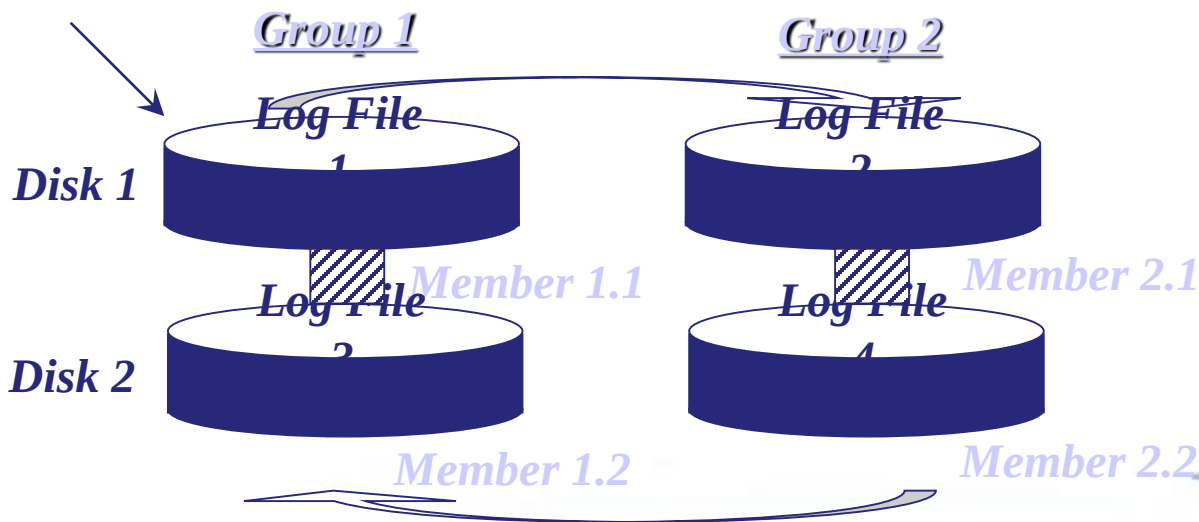


Oracle数据库物理存储结构：重做日志文件

重做日志文件（Redo Log File）记录所有对数据库数据的修改，以备恢复数据时使用。

其特点如下：

- 每一个数据库至少包含两个日志文件组
- 日志文件组以循环方式进行写操作
- 每一个日志文件成员对应一个物理文件





Oracle数据库物理存储结构：控制文件

控制文件（Control File）是一个较小的二进制文件，用于描述数据库结构。

描述信息

- 数据库建立的日期
- 数据库名
- 数据库中所有数据文件和日志文件的文件名及路径
- 恢复数据库时所需的同步信息

要点注意

- 在打开和存取数据库时都要访问该文件
- 记录控制文件名及路径的参数为 CONTROL_FILES

可以将控制文件理解为物理数据库的一个元数据存储库



Oracle数据库物理存储结构：参数文件

参数文件（Parameter File）也被称为初始化参数文件，用于存储SGA、可选的Oracle特性和后台进程的配置参数。

当数据库启动，并在创建例程或读取控制文件之前，会先按其中的参数进行例程的配置。

位置：\$Oracle_home\ dbs \ init.ora





Oracle数据库物理存储结构：口令文件

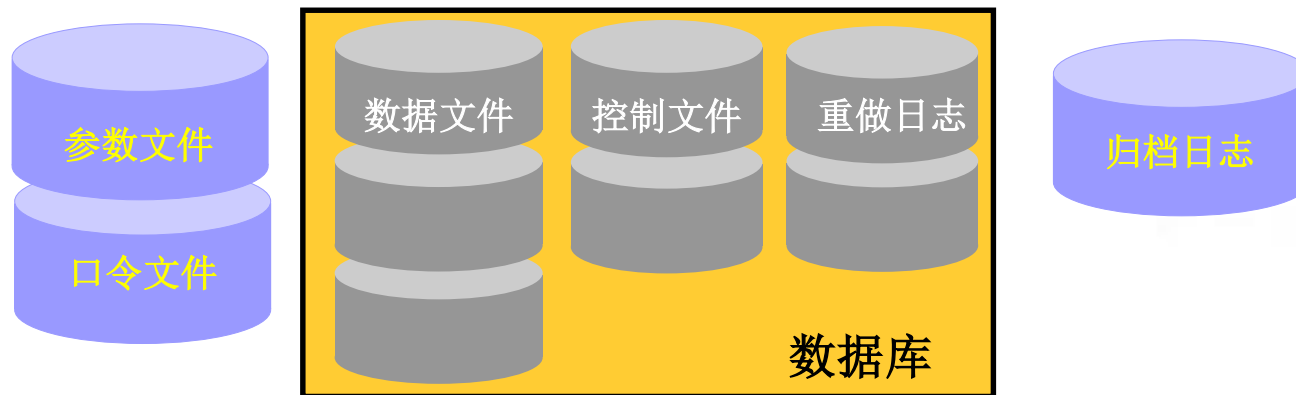
口令文件：是个二进制文件，验证特权用户

位置：\$Oracle_home\ database\PWD%.ora

windows的口令文件位置：

C:\windows\System32\config\SAM

归档日志文件：非活动的重做日志文件的备份





Oracle数据库逻辑存储结构

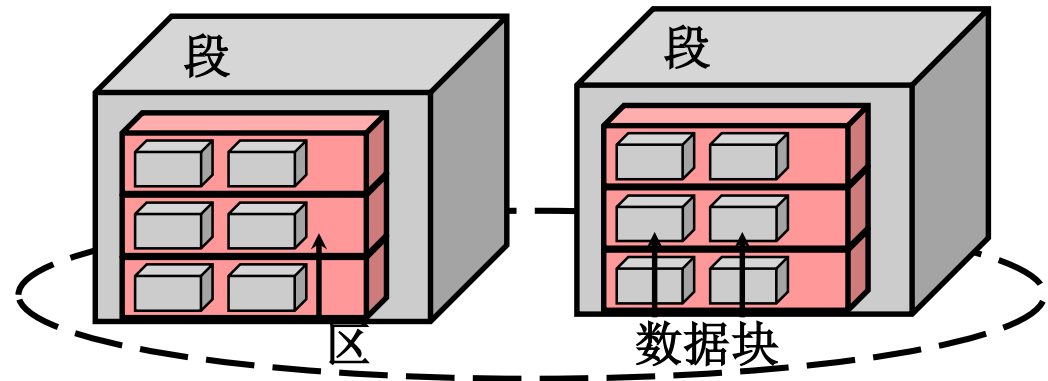
主要描述Oracle数据库的内部存储结构，从技术概念上描述Oracle数据库中如何组织、管理数据

- 可以分为4部分：表空间、段、区、块

Oracle的逻辑结构是由一个或多个表空间组成

- 一个表空间 (tablespace) 由一组段组成
- 一个段 (segment) 由一组区组成
- 一个区 (extent) 由一批数据库块组成
- 一个数据库块 (block) 对应一个或多个物理操作系统块

表空间



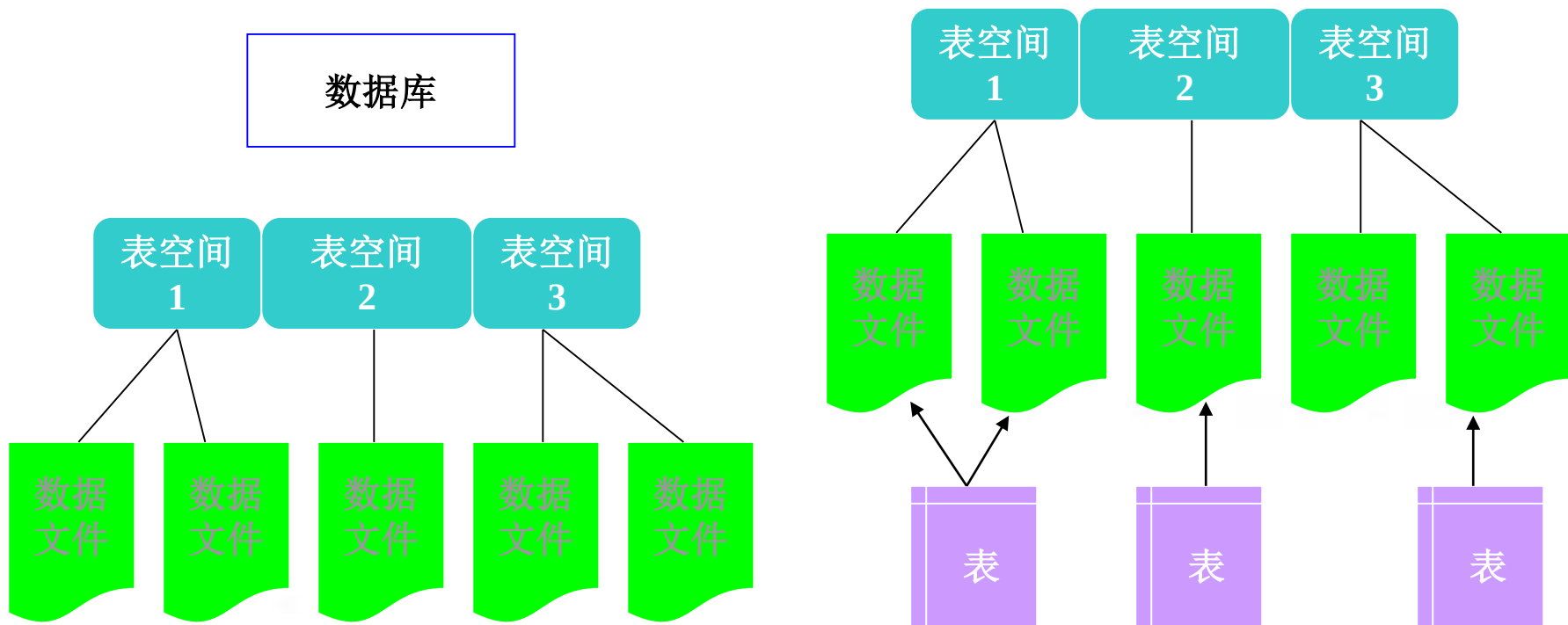
如果把Oracle数据库类比为房间，表空间可看作这个房间对应的空间，是可以自由分配的。在这空间里面可以堆放多个箱子（箱子可被看作是数据库文件），箱子里面再装物隔板（隔板可看作为表）。用户指定表空间也就是希望把属于这个用户的表放在那个房间（表空间）里面。



Oracle数据库逻辑存储结构：表空间

表空间是数据库的逻辑划分的最大单元，一个Oracle数据库至少有一个表空间，即system表空间。表空间的设计理念为Oracle的高性能做出了不可磨灭的贡献，其很多优化都是基于该理念而实现的。

表空间是ORACLE数据库恢复的最小单位，容纳着许多数据库实体，如表、视图、索引、聚簇、回退段和临时段等。





安装完Oracle 10g后自动创建的表空间

表空间名称		表空间的作用
SYSTEM	系统表空间	存放关于表空间名称、控制文件、数据文件等管理信息，它属于sys、system方案。不能删除或重命名。
SYSAUX	辅助系统表空间	用于减少系统表空间的负荷，提高效率。是Oracle 10g新增加的表空间。
Example	示例表空间	存放例子数据库的方案对象。
TEMP	临时表空间	存放临时表和临时数据，用于排序。
USERS	用户表空间	存放永久性用户对象及私有信息，也称数据表空间。注意：每一个数据库都应该有一个用户表空间，以便在创建用户时分配给用户，否则用户的数据将会使用SYSTEM表空间。
UNDOTBS1	重做表	



Oracle数据库逻辑存储结构：典型应用

典型应用一：控制用户所占用的表空间配额

在一些大型的数据库应用中，DBA需要控制某个用户或者某一组用户所占用的磁盘空间。这就好像在文件服务器中，需要为每个用户设置磁盘配额一样，以防止硬盘空间耗竭。所以，在数据库中，我们也需要限制用户所可以使用的磁盘空间大小。

可以通过表空间来实现这个目的。DBA在Oracle数据库中，建立不同的表空间，为其设置最大的存储容量，然后把用户归属于这个表空间。

如此的话，这个用户的存储容量，就受到这个表空间大小的限制。



Oracle数据库逻辑存储结构：典型应用

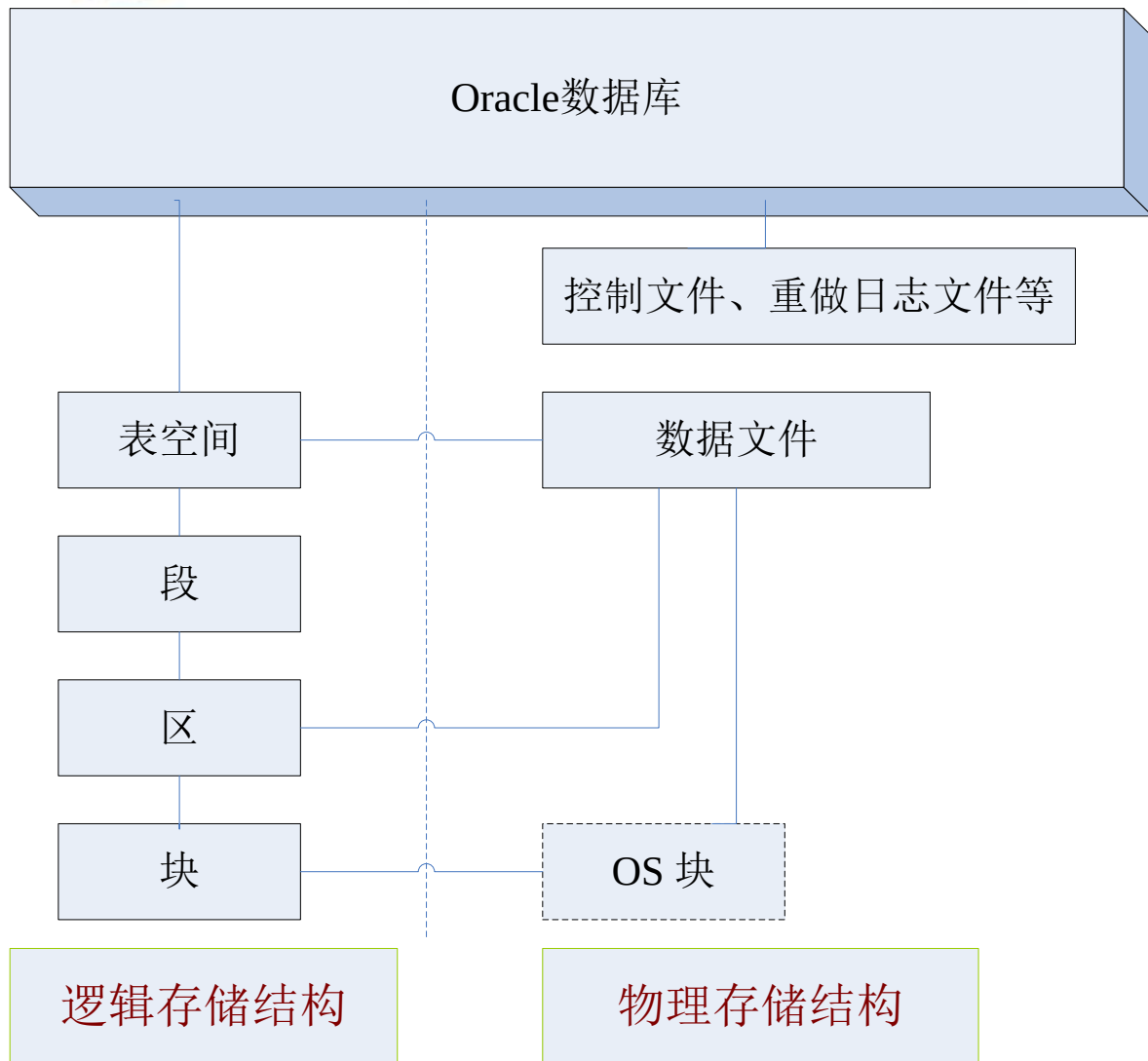
典型应用二：控制数据库所占用的磁盘空间

有时候，在Oracle数据库服务器中，可能运行的不止一个服务。除了数据库服务器外，可能还有邮件服务器等应用系统服务器。为此，就需要先对Oracle数据库的磁盘空间作个规划，否则当多个应用程序服务所占用的磁盘空间都无限增加时，最后可能导致各个服务都因为硬盘空间的耗竭而停止。

在同一台服务器上使用多个应用程序服务，往往需要先给它们进行磁盘空间的规划和分配。各个服务都不能够超过最大限额，或者超过后及时发出警报。



Oracle存储结构：小结



- ❑ 从物理上看，数据库由控制文件、数据文件、重做日志文件等操作系统文件组成；
- ❑ 从逻辑上来看，数据库是由系统表空间、用户表空间等组成。
- ❑ 表空间是最大的逻辑单位，块是最小的逻辑单位。



Oracle数据库的三种结构：内存结构

Oracle内存结构由两个部分组成：

- 系统全局区 (SGA) ——在启动例程时分配，是Oracle例程的基础组件
- 程序全局区 (PGA) ——当启动服务器进程时分配



系统全局区 (SGA)

SGA是ORACLE系统为例程分配的一组共享缓冲存储区，用于存放数据库数据和控制信息，以实现对数据库数据的管理和操作。

SGA是不同用户进程与服务进程进行通信的中心。

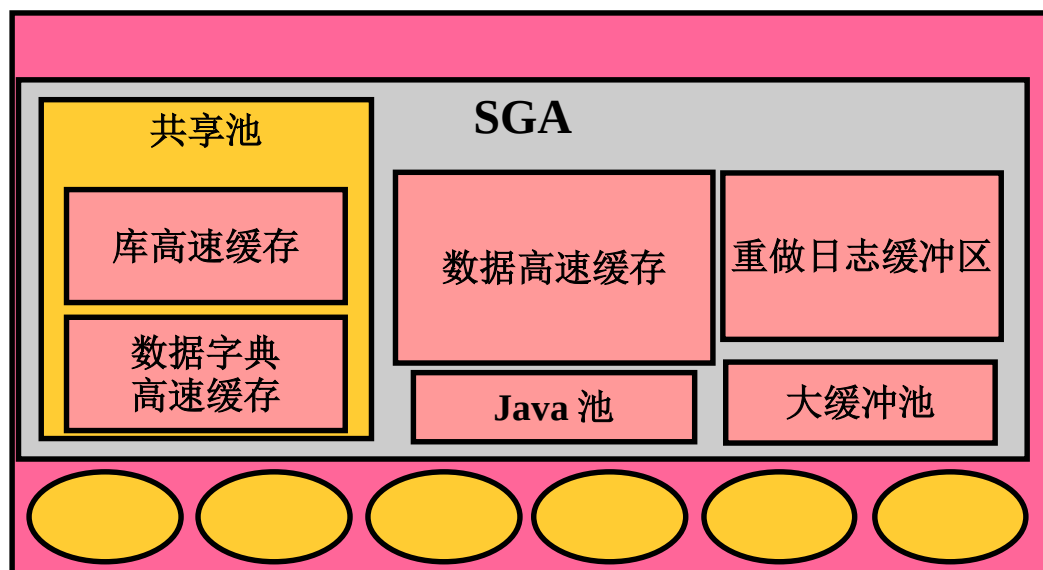
- 数据库的各种操作主要在SGA中进行，所以称其为系统全局区

- 每个例程都只有一个SGA
- 创建例程时，Oracle为SGA分配内存
- 终止例程时，释放SGA所占用的内存



系统全局区 (SGA)

- SGA由以下内存结构组成
 - 共享池
 - 数据高速缓存
 - 重做日志缓冲区
- 在SGA内可以配置以下内存结构
 - 大缓冲池
 - Java池

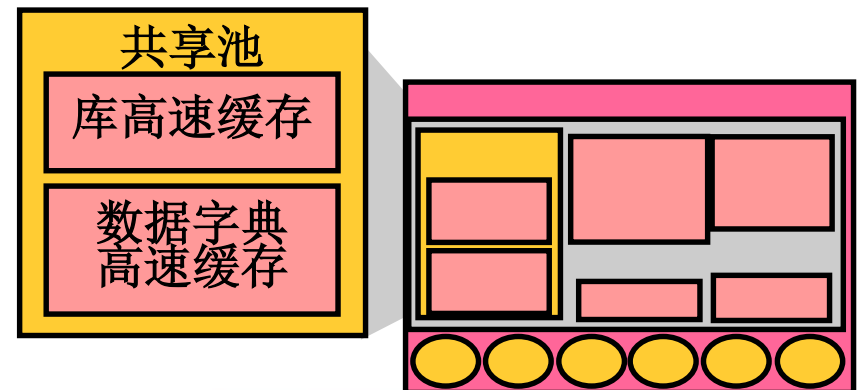




共享池

- 用于存储:
 - 最近执行的SQL语句
 - 最近使用的数据定义
- 由两个关键的内存结构组成:
 - 库高速缓存
 - 数据字典高速缓存
- 尺寸由参数SHARED_POOL_SIZE控制

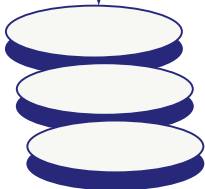
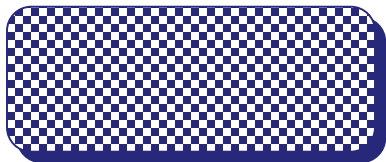
```
ALTER SYSTEM SET  
SHARED_POOL_SIZE = 64M;
```





数据高速缓存

数据缓冲区



数据文件

- 初次访问数据时，Oracle将读取磁盘上的数据文件，将数据放入数据高速缓存，再处理数据；
- 如果数据已经位于数据高速缓存中时，Oracle直接操作数据。

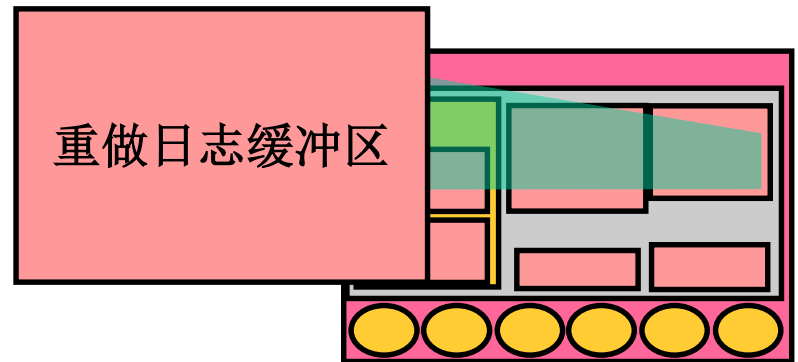


重做日志缓冲区

记录所有数据块变化，主要目的是恢复。

当执行DML（如update、delete、insert或者create、alter、drop等语句）时，Oracle都会为这些操作生成重做记录

- Oracle总是先记录日志、后记录数据
- 由LOG_BUFFER初始化参数定义

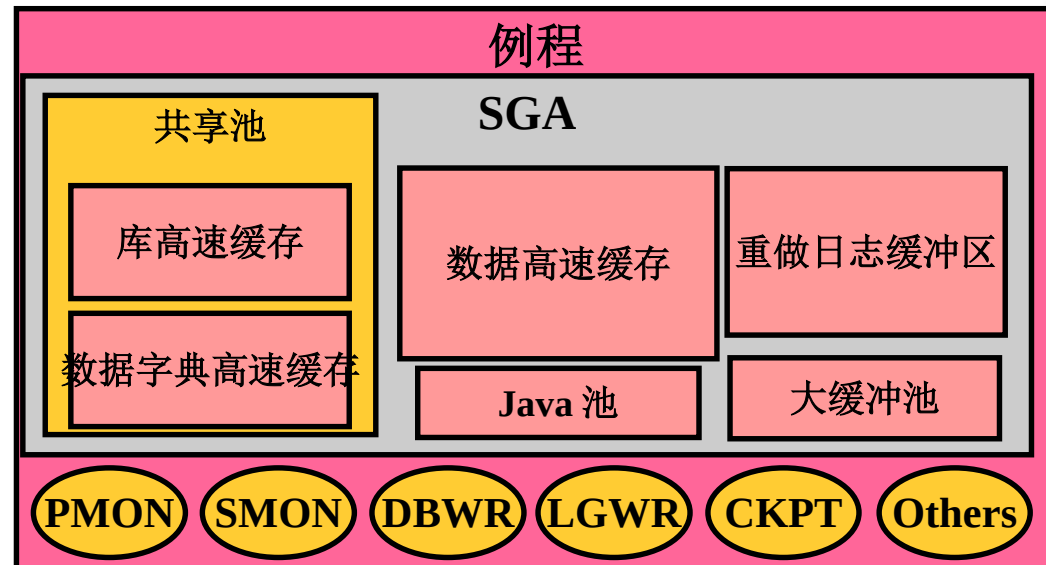




大缓冲池

大缓冲池用于为需要大内存的操作提供相对独立的内存空间，以便提高性能。

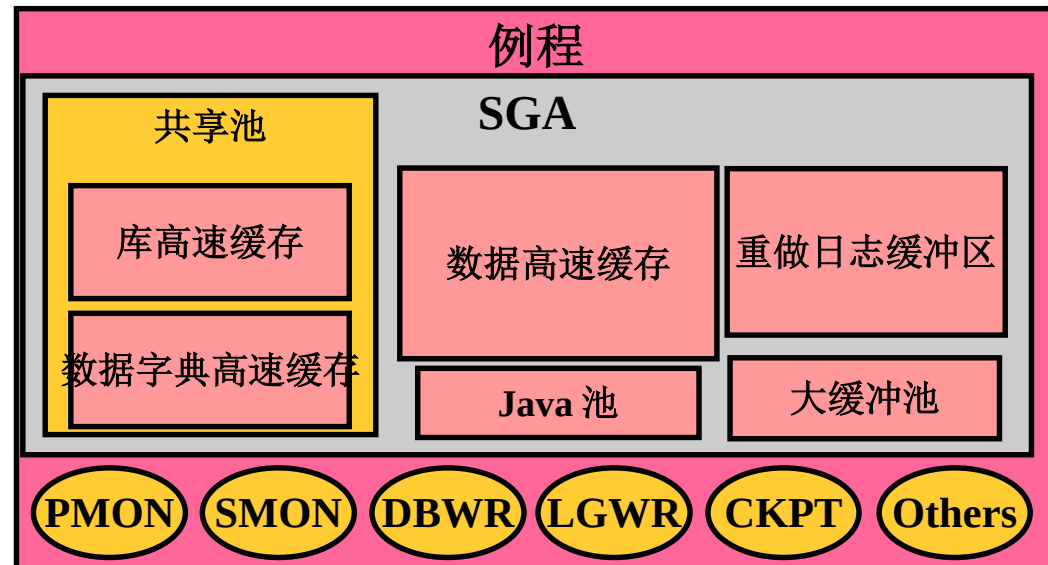
- ❑ 大池是可选的内存结构
- ❑ DBA可以决定是否需要在SGA中创建大池
- ❑ 需要大池的操作
 - 数据库备份和恢复
 - 大量排序的SQL语句
 - 并行化的数据库操作





Java池

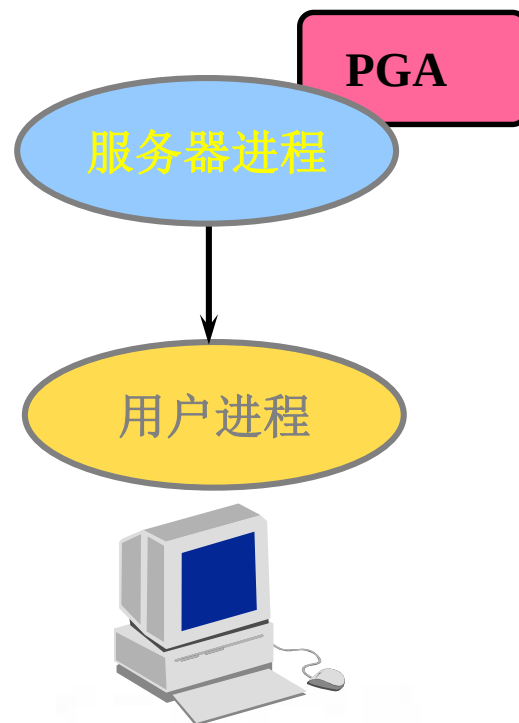
- 8i以后提供的对Java的支持，用于存放Java代码、Java程序等。
- 一般不小于20M，以便虚拟机运行
- 尺寸由JAVA_POOL_SIZE控制





程序全局区 (PGA)

- 为每个连接到数据库的用户进程预留内存
- 当建立服务器进程时分配
- 当终止服务器进程时释放
- 只能由一个进程使用





Oracle数据库的三种结构：进程结构

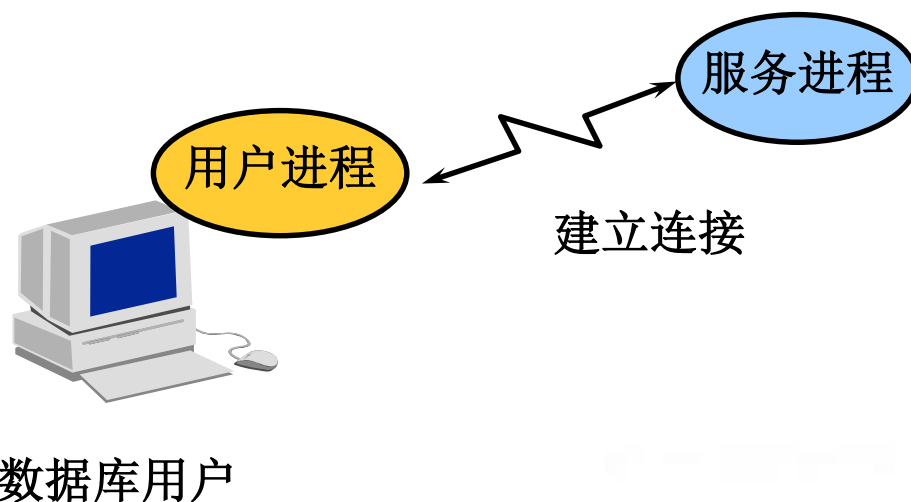
Oracle使用各种类型进程:

- 用户进程：当用户请求连接到Oracle server时启动
- 服务进程：连接到例程，并且当用户建立会话时启动
- 后台进程：当启动例程时启动



用户进程

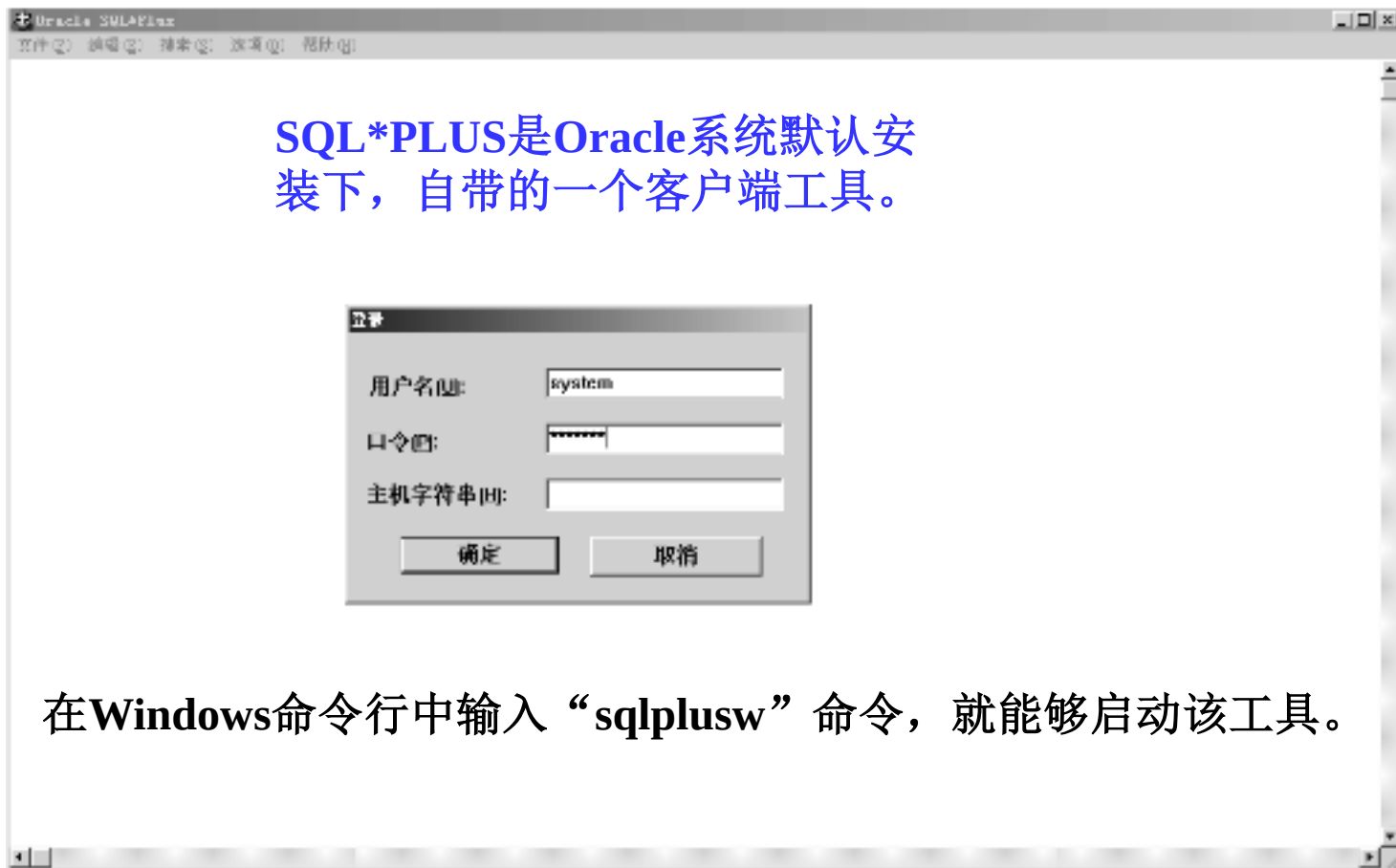
- 请求与Oracle server交互的程序
- 必须首先建立连接
- 不会与Oracle server直接交互





用户进程举例1

SQL*Plus工具



在Windows命令行中输入“sqlplusw”命令，就能够启动该工具。



用户进程举例2

SQL*Plus命令行工具



```
C:\WINDOWS\system32\cmd.exe - sqlplus /nolog

C:\Documents and Settings\Administrator>sqlplus /nolog

SQL*Plus: Release 10.2.0.3.0 - Production on 星期一 8月 24 18:03:27 2009

Copyright (c) 1982, 2006, Oracle. All Rights Reserved.

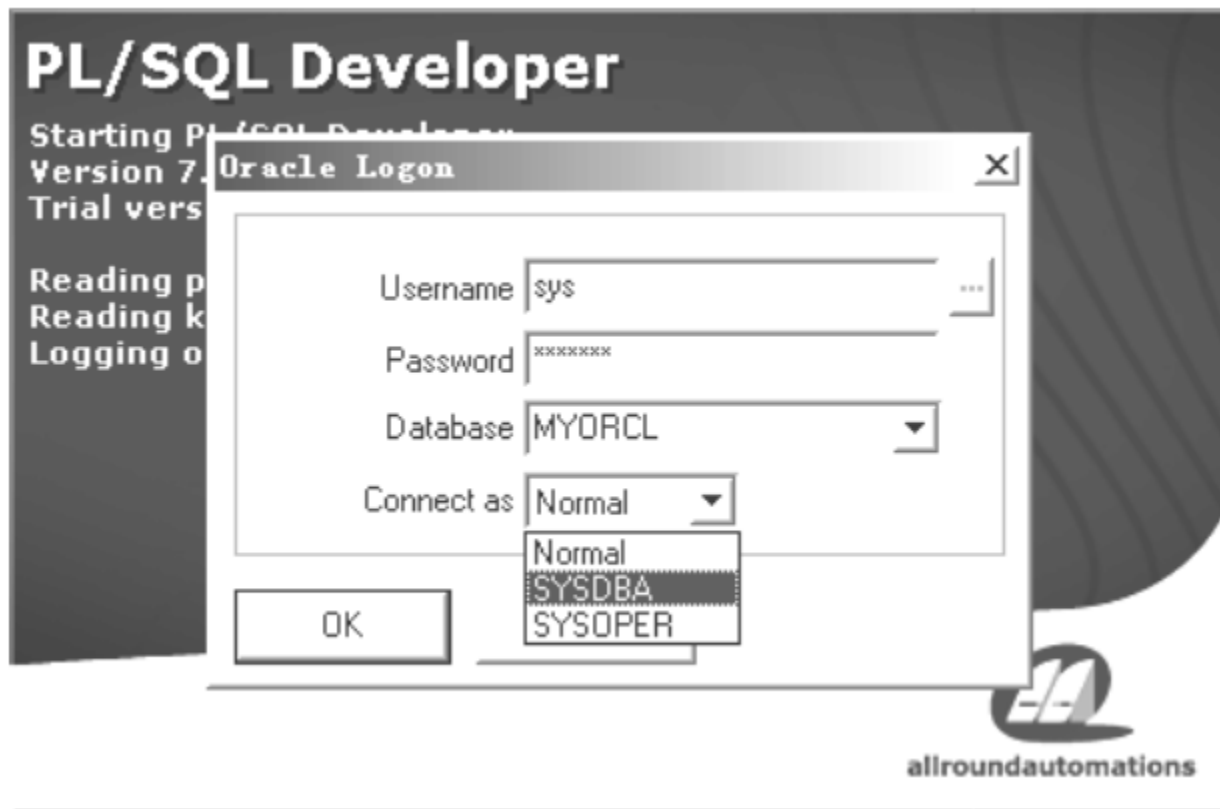
SQL> conn sys/stephen as sysdba;
已连接。
SQL> _
```

提供了与数据库交互的能力和维护数据库的能力，包括了Oracle自带的SQL*Plus工具的全部功能，在Oracle管理中经常使用。
在命令行中输入：`sqlplus /nolog`即可启动该工具。



用户进程举例3

PL/SQL Developer工具

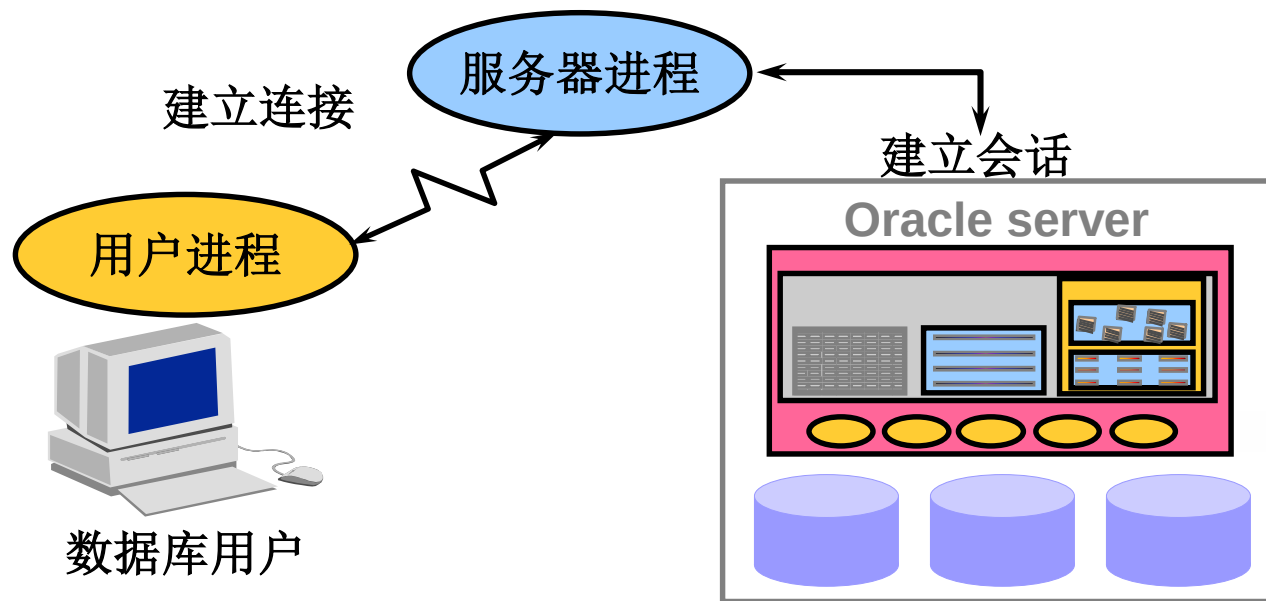


一个功能强大的第三方工具。**PL/SQL Developer**基本上可以实现**Oracle**开发中的任何操作。它运行在客户端时必须先安装**Oracle**客户端，并且通过网络配置向导配置网络服务名后才能正常与服务器连接。



服务器进程

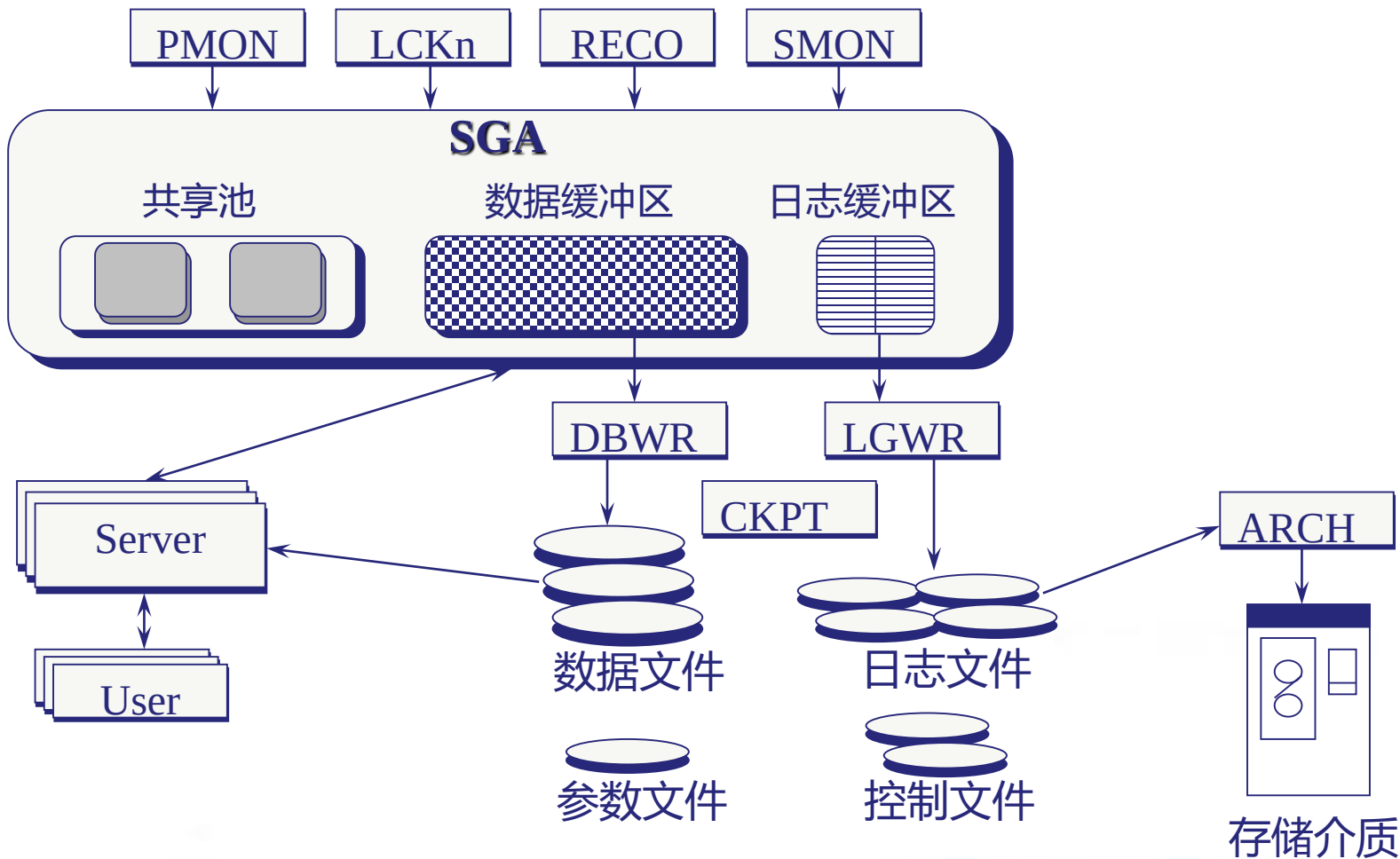
- 直接与Oracle server交互的程序
- 完成调用并返回结果
- 可以是专用的或者共享的





后台进程

作用：维护并加强物理结构和内存结构的关系。





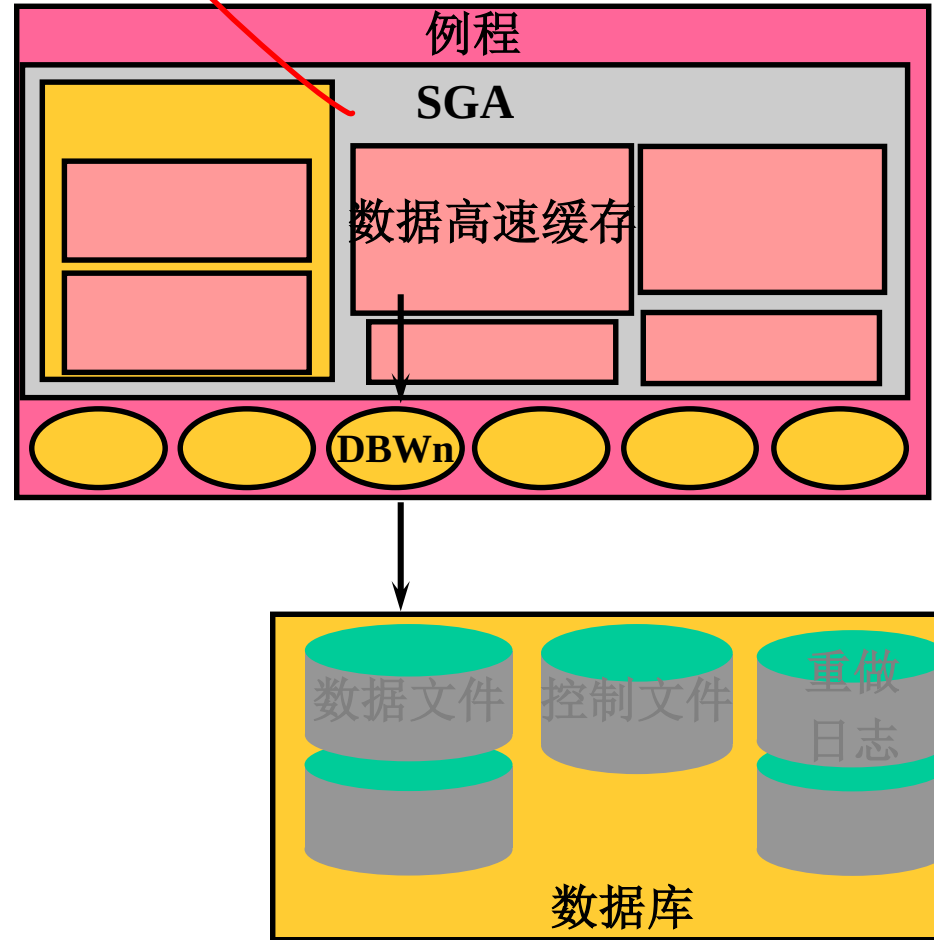
DBWn

1. 作用

把Database buffer cache中的脏数据写到data files 中。

2. 启动DBWR的条件

- 检查点
- DBWR timeout
- 没有空闲空间
- 脏缓存块达到一定数量





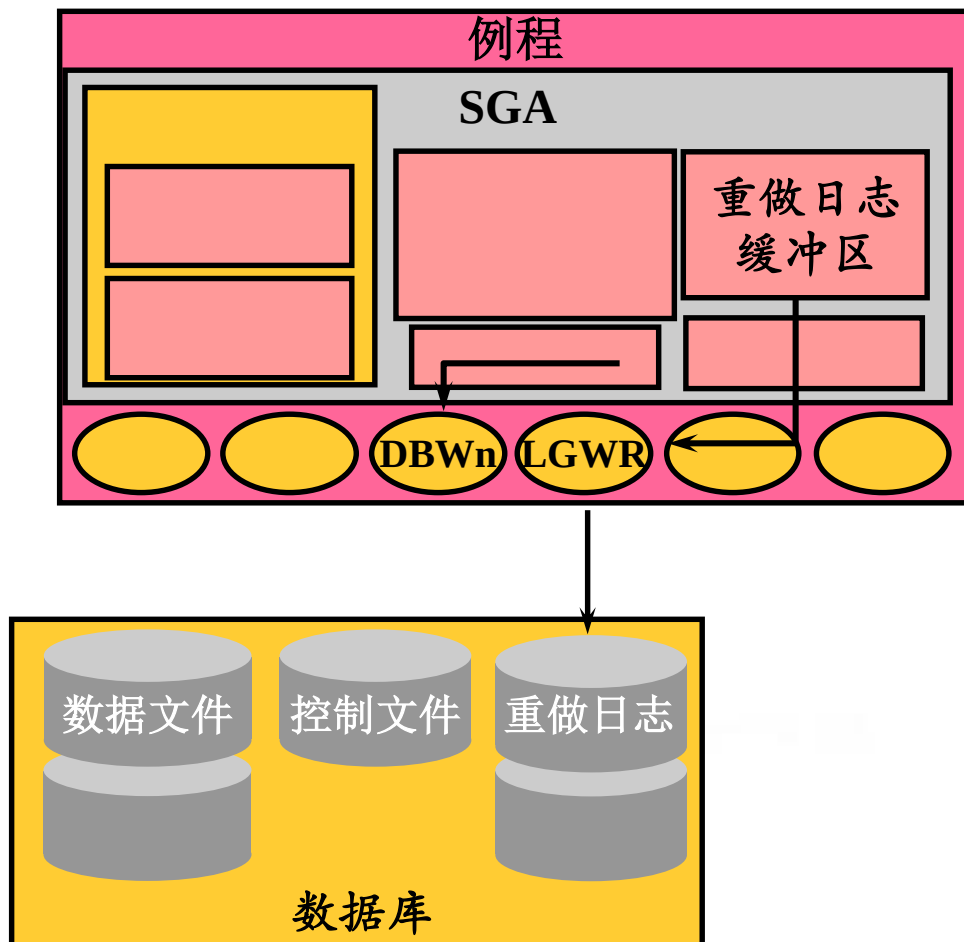
~~LGWR~~

1. 作用

把Redo log buffer中的内容
写到Redo log files中。

2. 启动LGWR的条件

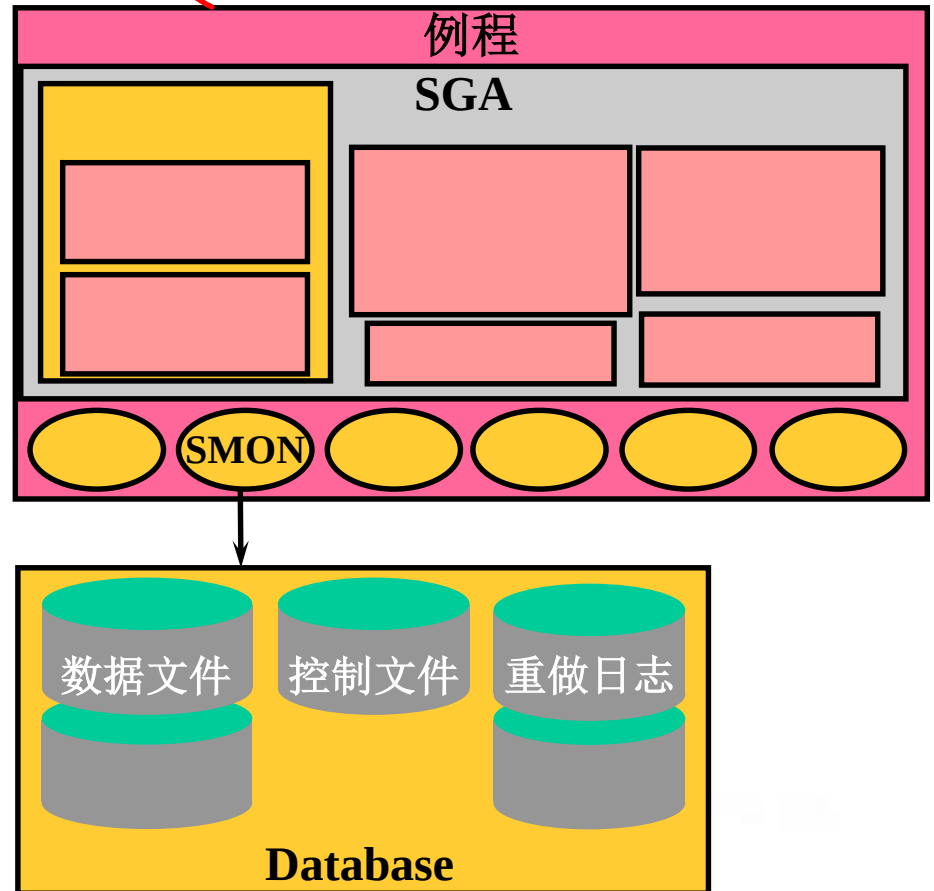
- 在事务提交时重作日志高速缓存被写满1/3
- 没有空闲空间将脏缓存块写入数据文件
- LGWR进程TimeOut





~~SMON~~

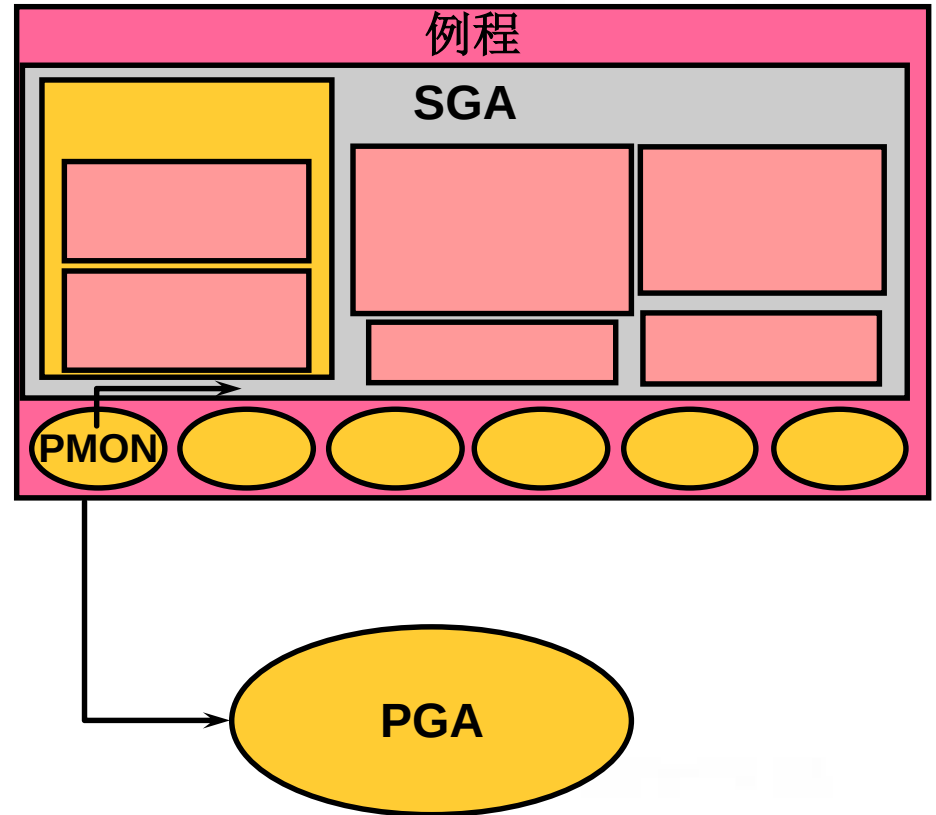
- 1、在例程启动时负责对数据库进行恢复；
- 2、将各个表空间的空闲空间碎片合并在一起，使之更容易分配；
- 3、清理不再使用的临时段。





~~PMON~~

- 1、恢复中断或失败的用户进程、服务进程；
- 2、回退未提交事务；
- 3、监视服务进程和调度进程，如果它们失败，则自动重启他们。

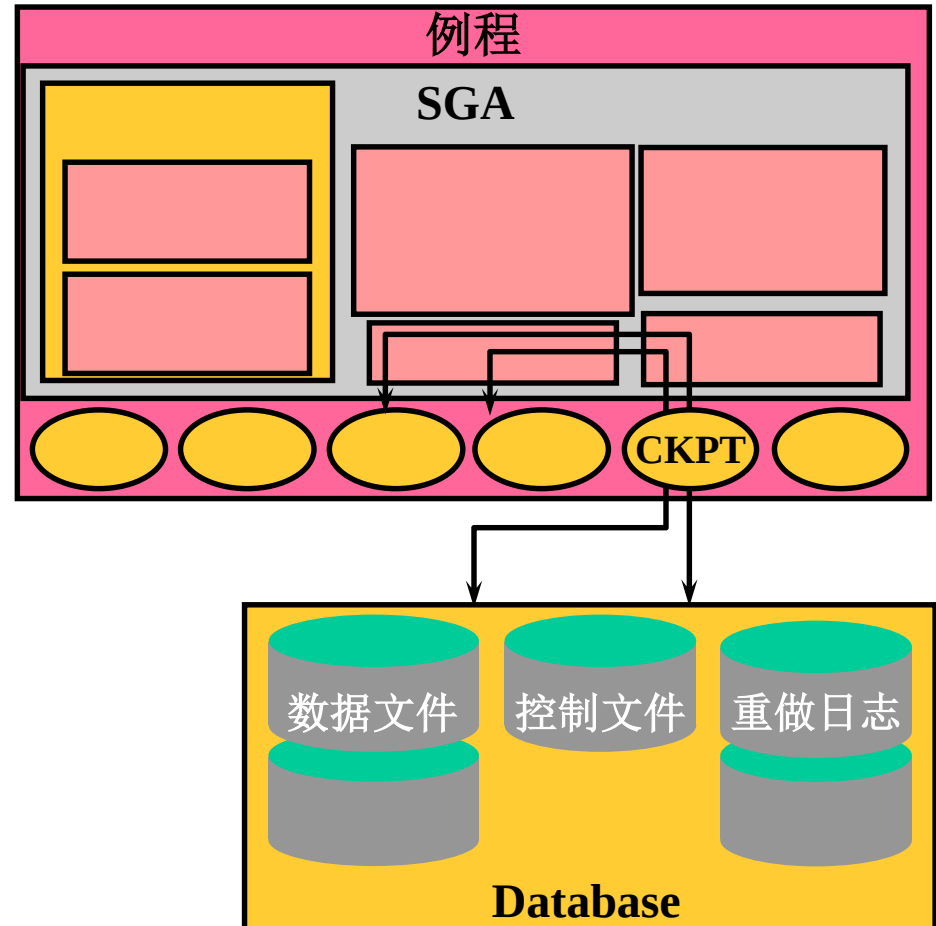




~~CKPT~~

执行检查点督促下列进行：

- 更新控制文件与数据文件使其同步；
- 触发DBWR进程，使其将脏读缓存块写入数据文件。

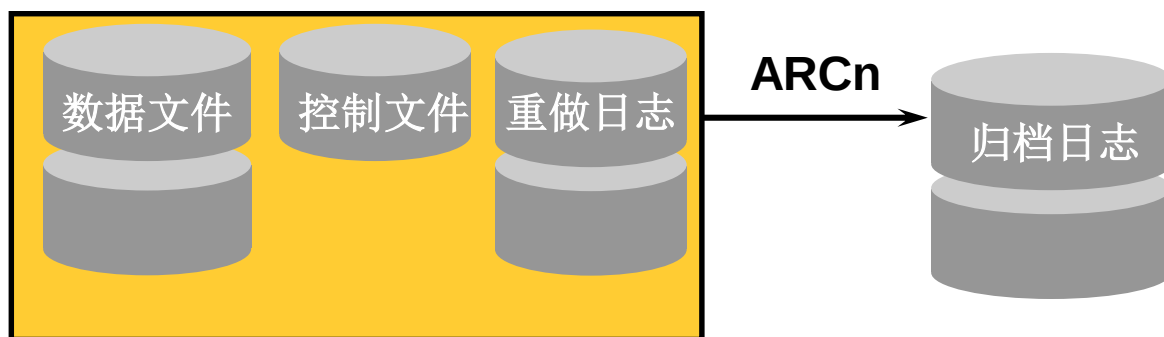




~~ARCn~~

负责将已经写满的重做日志文件备份到归档日志文件中，以防止循环写入重做日志文件时将其覆盖。

只有数据库运行在归档模式（ARCHIVELOG）时，
ARCH进程才能被启动。





Oracle体系结构小结

Oracle数据库包括DB和DBMS两部分

这两部分分别对应着database和例程。

Oracle数据库的database的存储结构

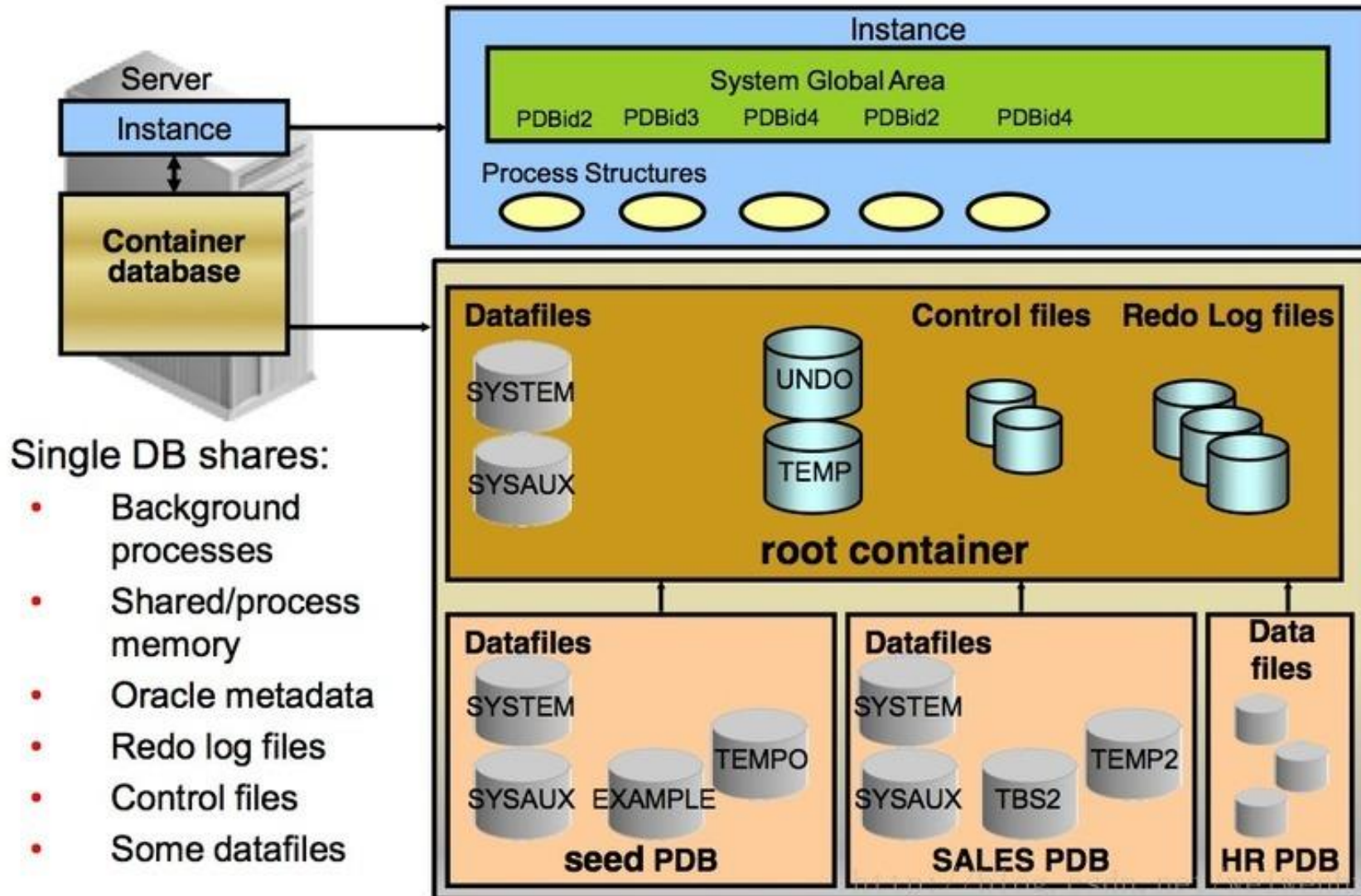
物理存储结构、逻辑存储结构。

Oracle数据库的例程部分

内存结构、进程结构。



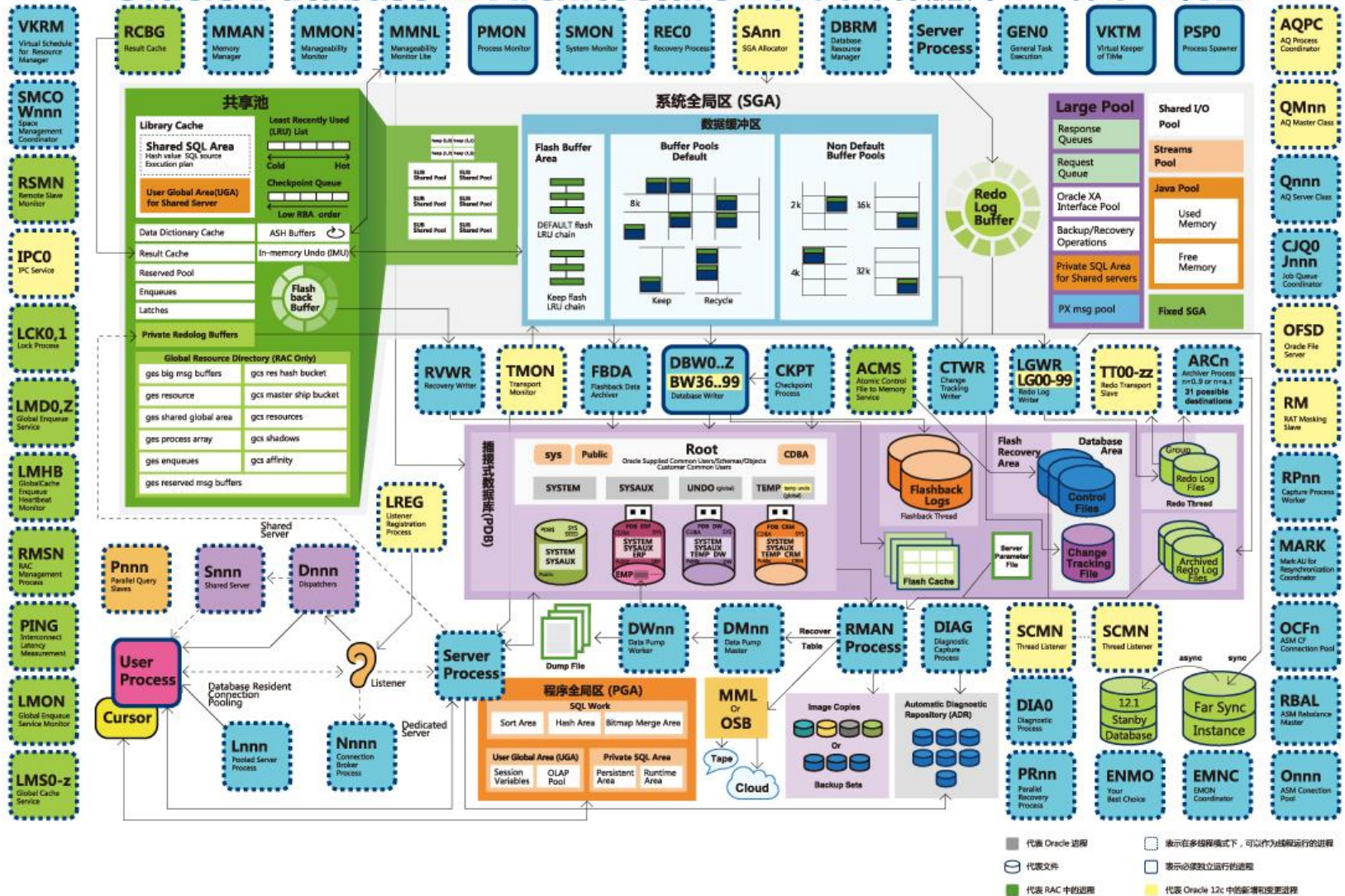
Latest Oracle version—12c





Latest Oracle version—12c

Oracle Database 12c Architecture | Oracle 数据库 12c 体系结构图



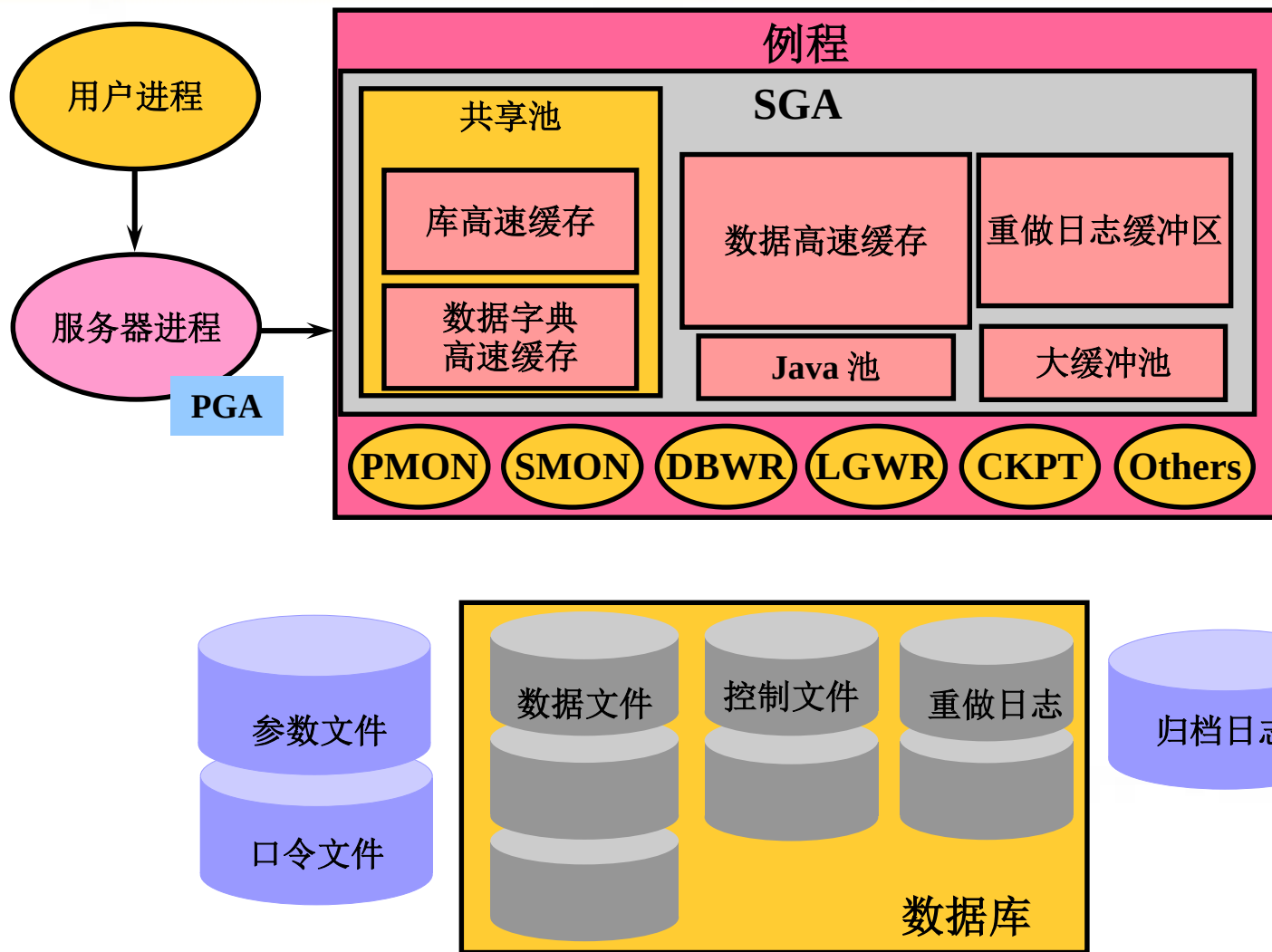


~~X~~ Latest Oracle version—12c

- 云端数据库整合的全新多租户架构、数据自动优化、深度安全防护、面向数据库云的最大可用性、高效的数据库管理以及简化大数据分析
- 这些特性可以在高速度、高可扩展、高可靠性和高安全性的数据库平台之上，为客户提供一个全新的多租户架构，用户数据库向云端迁移后可提升企业应用的质量和性能，还能将数百个数据库作为一个进行管理，帮助企业迈向云的过程中提高整体运营的灵活性和有效性。



思考：哪些地方会有安全问题？





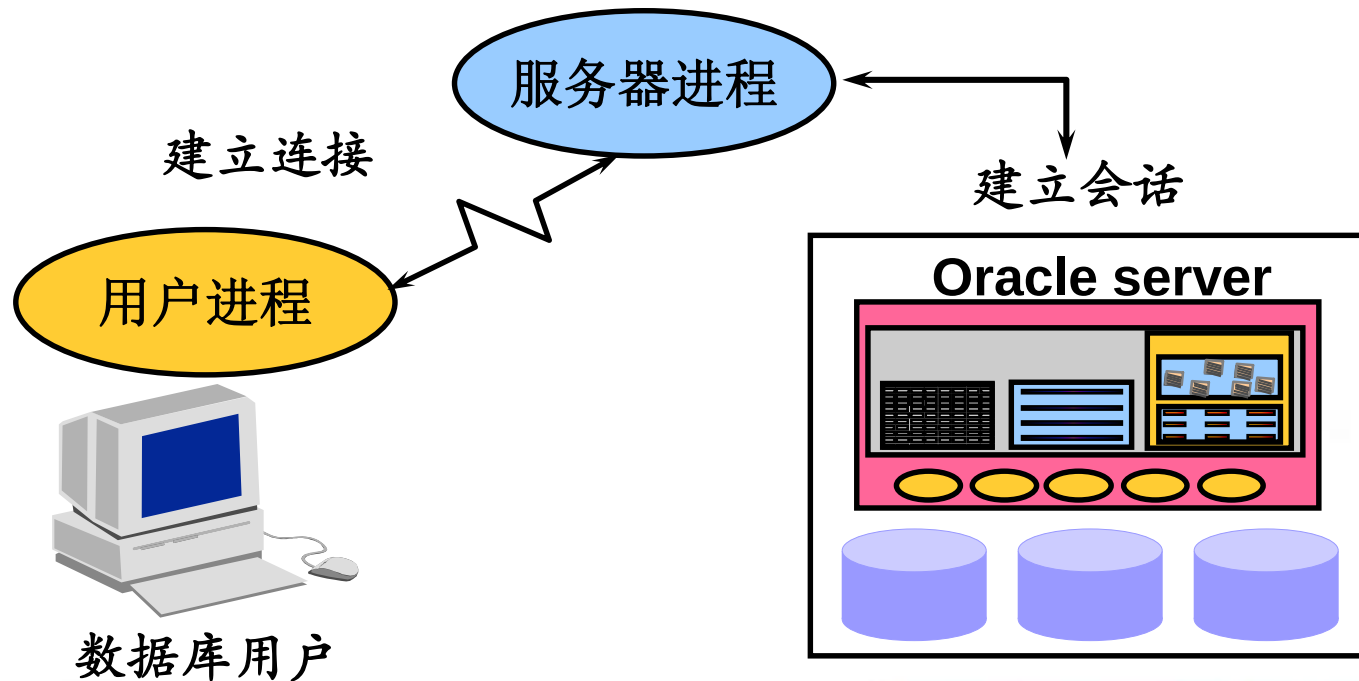
用户连接到例程

- 建立用户连接
- 建立会话
- 会话过程

建立连接是一个安全审核的过程。包括：提交的网络服务名是否正确；输入的用户名及密码是否存在且正确，连接的数据库对象是否存在等，对这些一系列的过程进行审核。

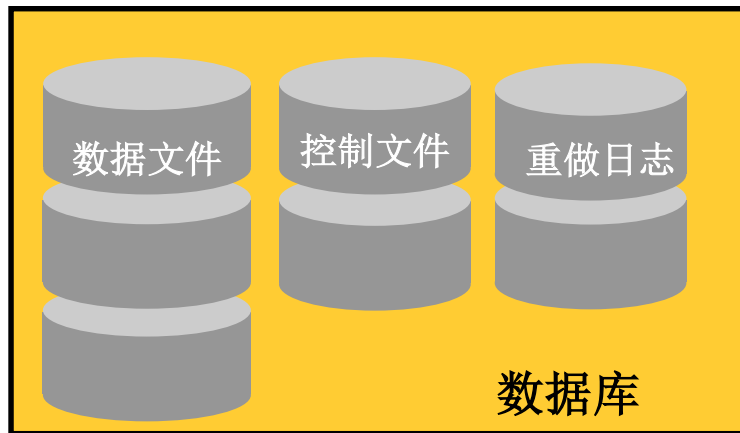
通过用户进程来连接。一旦建立了连接，Oracle服务器会给该用户调度一个服务器进程来完成该用户的请求命令服务。

服务器进程解析用户进程提交过来的SQL语句，完成该次会话执行的各种任务。





数据安全



Oracle
安全机制



传统安全方案的缺陷

1. 网络防火墙产品不对数据库通信协议进行控制

e.g., TNS协议是ORACLE服务端和客户端通信的协议

2. IPS/IDS/网络审计并不能防范那些看起来合法的数据访问

3. WAF系统仅针对HTTP协议进行检测控制，绕过WAF有150多种方法

4. 核心数据库防护措施被忽略。大多数系统前端层面的安全保护措施并无法覆盖所有的安全攻击和窃取——必须引入数据层面的保护作为最后一道安全防线。



数据库运维面临很多安全隐患

数据库口令暴露

- 运维、开发人员知晓数据库口令；
- 任意客户端登录；
- 无统一访问出入口

存在高危操作

- 随意操作数据库对象；
- 恶意操作行为；
- 误操作、高危操作

用户身份不清

- 公用设备、公用账户

怎样去解决呢？

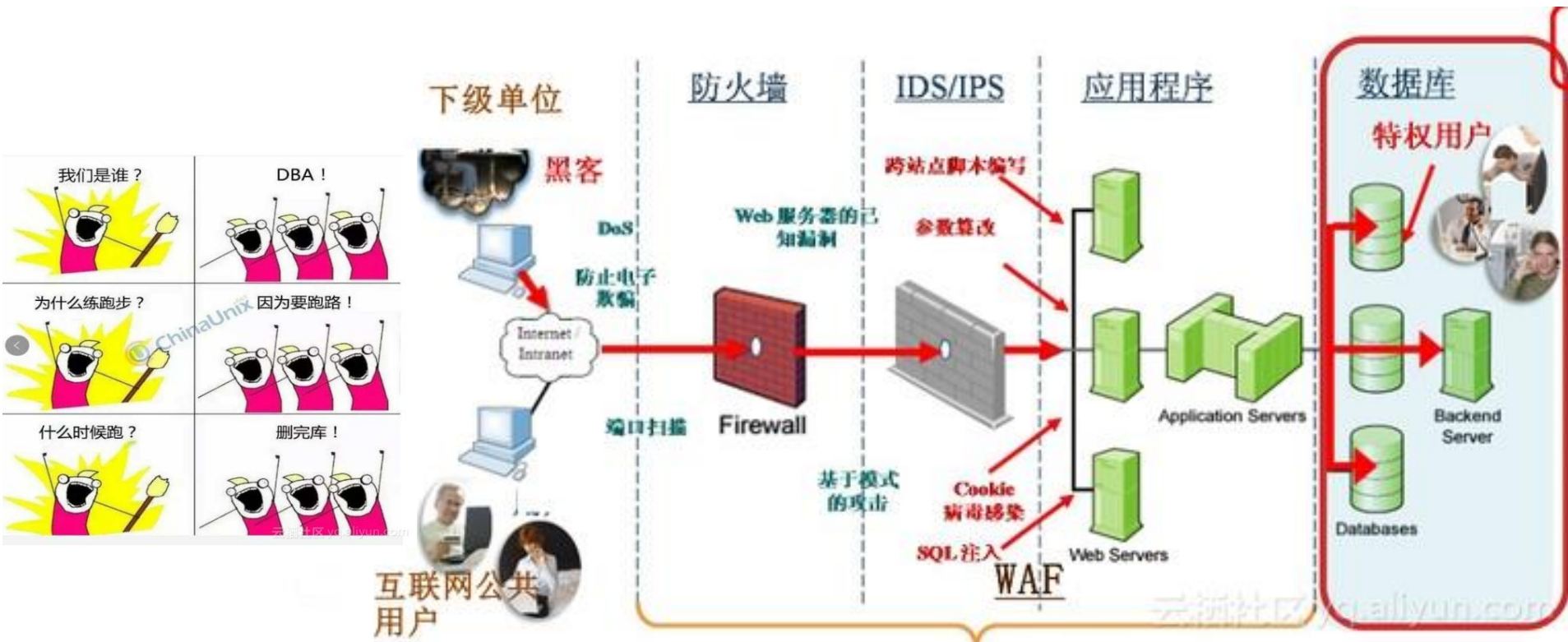
安全运维需要规范运维行为，具体包括三点：

1. 身份识别：解决口令外泄，区分人员身份
2. 访问审批：预防高危操作，避免越权操作
3. 流程管理：规范流程管理，有效追责定责



我们需要什么样的安全

数据安全面临的问题概括为两点，一是防外贼，一是防内鬼。外贼包括SQL注入、拖库，内鬼包括内部运维人员、第三方开发人员。从实际了解情况来看，内鬼的危害更大。





Oracle的安全机制

❑ 数据的备份与恢复

- 为保证数据的完整性和一致性，防止因故障而导致的数据破坏和灾难而采取的防范措施。

❑ 用户管理

- 用户身份认证、角色与权限等；

❑ 资源管理

- 通过系统概要文件限制连接会话等；



用户管理

□ 用户类别

- 在数据库系统中，根据工作性质和特点，用户可分成三类：数据库管理员（DBA）、数据库开发人员和普通用户。
- 不同类型的用户分别赋予不同的权限，从而保证数据库系统的安全。

□ 数据库管理员（DBA）

负责管理和维护数据库系统的正常运行，其主要职责包括：

- 安装并升级Oracle服务器和应用工具
- 配置和管理数据库
- 设置权限和安全管理
- 监控并优化数据库性能
- 备份和恢复数据库



用户管理

□ 数据库开发人员

负责设计和开发数据库应用程序，其主要职责包括：

- 设计应用的数据结构
- 估算应用的存储需求
- 给出应用数据库结构修改的说明
- 开发过程中优化应用
- 开发过程中构建应用的安全策略

以上工作需要和DBA协作。

□ 普通用户

普通用户指的是执行与数据库相关的日常操作的工作人员。



用户管理

- 通过创建、修改、删除和监视用户来控制用户对于ORACLE数据库的存取



**Database
Administrator**

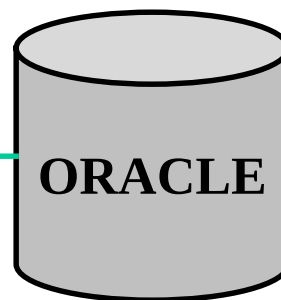
New Users



Username/Password

Access Privilege

Quotas



控制用户对数据库的存取:

1. 用户必须拥有必要的角色和权限，才能被数据库认可并在数据库中进行相应的活动
2. 限定每个用户使用磁盘空间的大小。



权限

权限指的是执行特定命令或访问数据库对象的权利

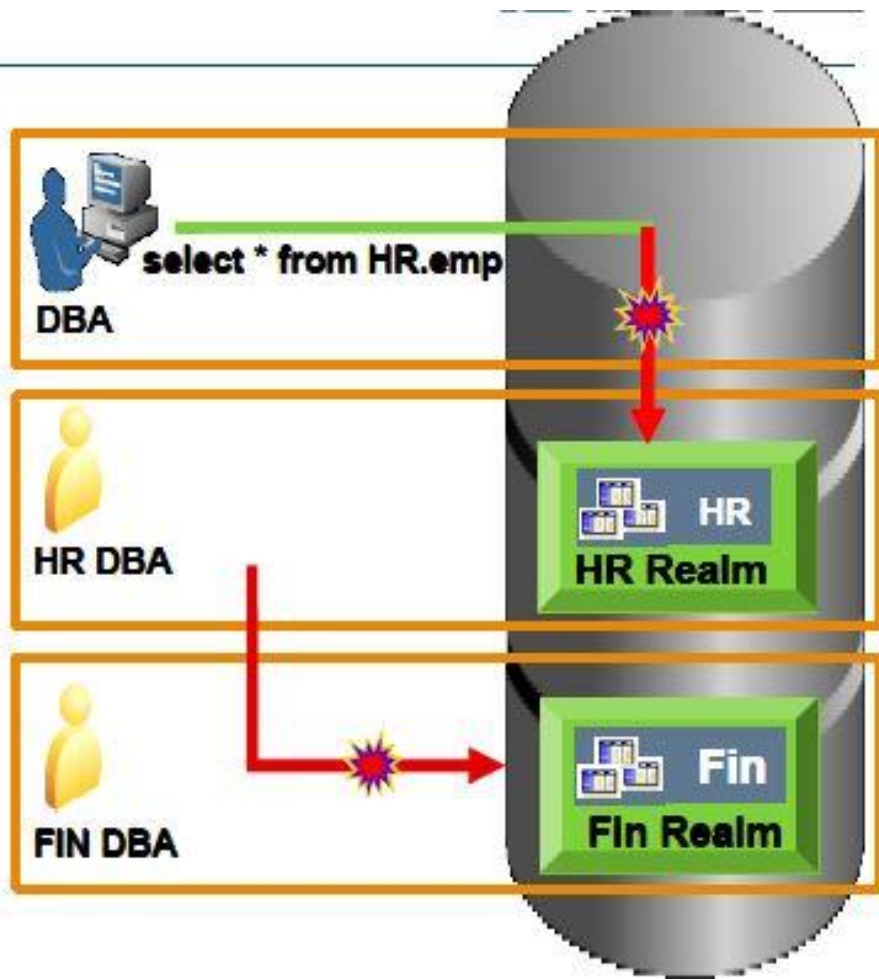
□ 权限有两种类型

- **系统权限**：Oracle有80多种系统权限，可使用户在系统范围内完成特定的操作。
- **对象权限**：允许用户在被指定用户所属的数据库对象（如表、视图、序列等）完成特定操作。



如何限制“上帝”的权利

从宏观方面看，Vault属于Oracle数据库安全领域中-访问控制的部分

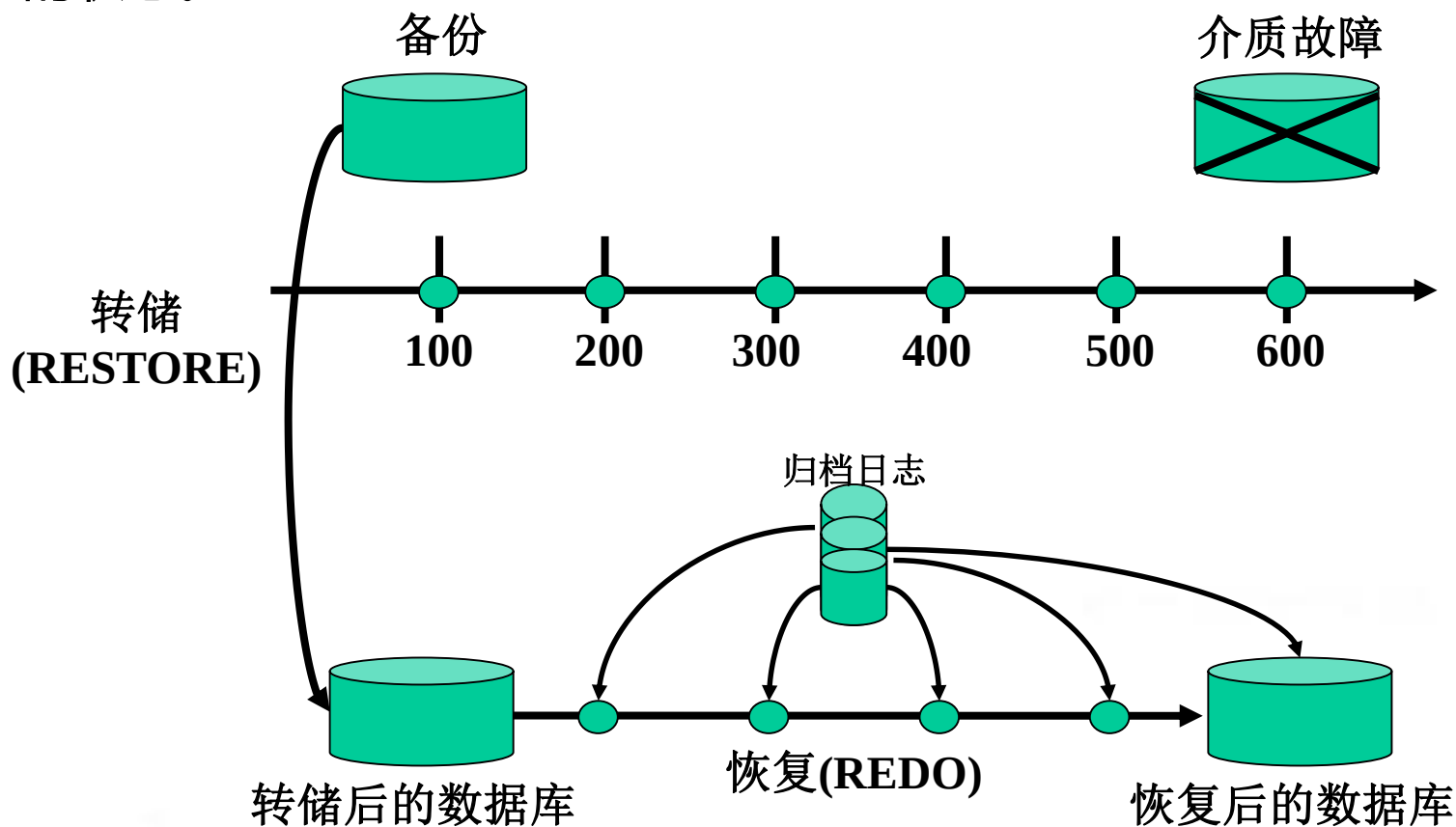


Vault最主要的目的是为了防止具有sys账户DBA滥用权限。在没有vault情况下，DBA可以随意查看数据，这对于一些企业（特别是金融领域）来说是不允许的，而有了Vault，就可以控制DBA不能访问应用的核心数据。



数据的备份恢复

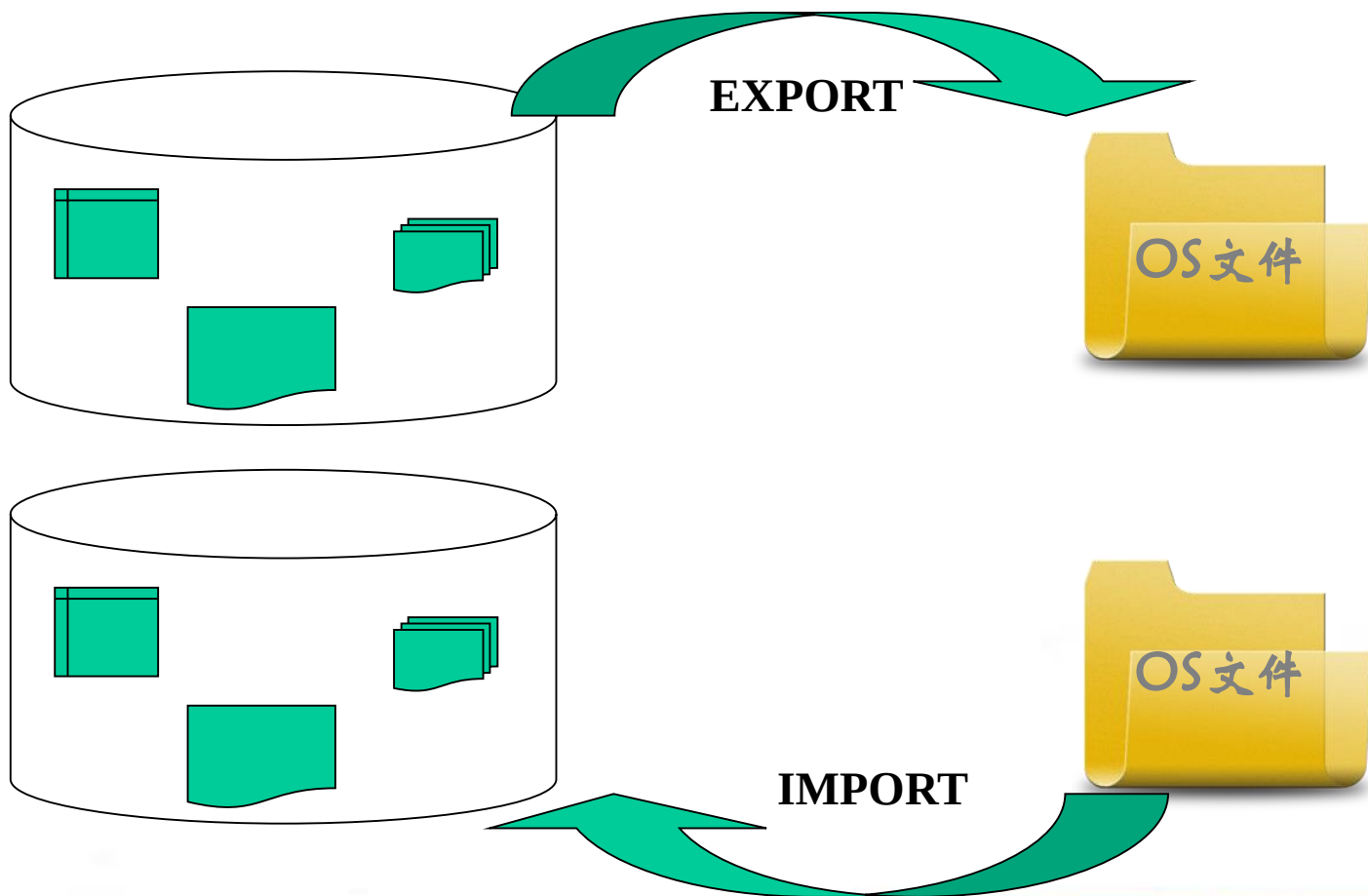
当数据库出现介质或者用户误操作时，使用已备份数据文件、归档日志和重做日志将数据库恢复到备份点与故障点之间某个时刻的状态。





备份和恢复的方法

利用Oracle工具程序EXP和IMP（EXPDP和IMPDP）将数据库部分或全部对象的结构及其数据导出、导入。





数据泵

数据泵 (Data Pump) 是Oracle 10g提供的实用程序，它可以从数据库中高速导出或加载数据库的方法，可以**自动管理多个并行的数据流**。数据泵可以实现在测试环境、开发环境、生产环境以及高级复制或热备份数据库之间的快速数据迁移；数据泵还能实现部分或全部数据库逻辑备份，以及跨平台的可传输表空间备份。



~~闪回操作~~

闪回数据库是Oracle 9i引入的强大功能，这些功能在第二次发布的Oracle 9i中得到了增强。现在，Oracle Database 10g在闪回数据库方面提供了更多的功能。

闪回数据库允许用户将整个数据库闪回到指定的时间点。这种功能对于解决逻辑数据遭到破坏的问题是非常有效的。

在Oracle Database 10g系统中，可以从3种不同的工具中使用闪回数据库的功能。

- * SQL*Plus
- * RMAN
- * OEM



Summary of The Class



□ Oracle的体系架构

客户端 & 服务器端

服务器包括instance和数据库

存储结构、内存结构、进程结构

□ Oracle安全机制

用户管理、资源管理、备份与恢复